



UNIVERSIDAD TECNOLÓGICA DE PANAMÁ
FACULTAD DE INGENIERÍA DE SISTEMAS COMPUTACIONALES
LICENCIATURA EN INGENIERÍA DE SISTEMAS Y COMPUTACIÓN

Tópicos Especiales

Proyecto Final

Diseño e Implementación de Plan Integral de Ciberseguridad

GRUPO No. 2

Bethancourt, Cecydi [8-993-1290]

Casis, Diego [8-992-2136]

Hou, John [6-725-1535]

FACILITADOR

Prof. Xavier Trujillo

GRUPO

1M3213

FECHA DE ENTREGA

Jueves 9 de julio de 2026

Índice

MÓDULO 1. Panorama de Amenazas y Relación con el Caso	5
1.1 Introducción	5
1.2 Panorama actual de amenazas	5
1.3 Relación de las amenazas con el caso CREATIC	6
1.3.2 Credential Stuffing	6
1.3.3 Movimiento lateral	7
1.3.4 Ransomware	7
1.3.5 Explotación de aplicaciones vulnerables	7
1.3.6 Ruta de ataque probable en CREATIC	8
1.4 Mapeo de amenazas utilizando MITRE ATT&CK.....	8
1.5 Evaluación de impacto sobre la Triada CIA	10
1.5.1 Impacto directo de las amenazas principales.....	12
1.6 Conclusión del módulo.....	13
MÓDULO 2. Arquitectura de Red Moderna basada en Zero Trust y SASE.....	13
2.1 Diagnóstico de la arquitectura actual (Estado AS-IS)	13
2.2 Limitaciones del modelo de seguridad tradicional	14
2.3 Propuesta de Arquitectura Zero Trust	15
2.4 Arquitectura propuesta (Estado TO-BE)	15
2.5 Diseño de la Microsegmentación	17
2.6 Implementación de NGFW y WAF	19
2.7 Migración de VPN Tradicional a ZTNA.....	20
2.8 Flujo de autenticación con MFA.....	21
2.9 Evaluación de la postura del dispositivo	22
2.10 Beneficios de la arquitectura propuesta	23
2.11 Viabilidad económica y presupuesto estimado	24
MÓDULO 3. Operaciones de Seguridad y Protección de Endpoints bajo Restricción Presupuestaria	26
3.1 Introducción	26
3.2 Objetivos del SOC	27
3.3 Justificación tecnológica	27
3.4 Arquitectura del SOC	28

3.5 Fuentes de ingesta	29
3.6 Estrategia para dispositivos BYOD	30
3.7 Reglas de correlación	31
3.8 Automatización mediante SOAR.....	32
3.9 Dashboards	32
3.10 Beneficios	33
MÓDULO 4. Integración de DevSecOps en el Ciclo de Desarrollo Seguro	33
4.1 Introducción	33
4.2 Diagnóstico del proceso actual	34
4.3 Arquitectura DevSecOps propuesta.....	35
4.4 Flujo del Pipeline DevSecOps	36
4.5 Controles de seguridad implementados.....	37
4.5.1 Análisis Estático (SAST).....	37
4.5.2 Análisis de Dependencias (SCA).....	37
4.5.3 Detección de Secretos	37
4.5.4 Escaneo de Contenedores.....	38
4.5.5 Pruebas Dinámicas (DAST)	38
4.6 Integración con la Arquitectura Zero Trust	38
4.7 Integración con el SOC.....	39
4.8 Criterios de aprobación del pipeline.....	39
4.9 Beneficios de la propuesta.....	40
MÓDULO 5: Automatización de Hardening	40
5.1 Introducción	40
5.2 Objetivo del módulo	41
5.3 Alcance de la automatización	41
5.4 Arquitectura de archivos del repositorio	42
5.5 Hardening automatizado en Linux con Ansible	43
5.6 Verificación post-hardening en Linux	44
5.7 Hardening automatizado en Windows con PowerShell	48
5.8 Verificación post-hardening en Windows	49
5.9 Relación del hardening con Zero Trust y Defensa en Profundidad	53
5.10 Tabla de resumen de controles implementados.....	53
5.11 Evidencias generadas.....	54

5.12 Limitaciones del laboratorio	55
5.13 Resultado del módulo	55
5.14 Conclusión del módulo.....	56
MÓDULO 6: Cumplimiento Regulatorio	56
6.1 Introducción	56
6.2 Tabla de mapeo normativo Ley 81 y controles técnicos.....	57
6.3 Política de retención de logs	59
6.4 Justificación del MFA frente al Artículo 13 y el principio de seguridad	60
6.5 Conclusión del módulo.....	61
MÓDULO 7: Gestión de Riesgos y Respuesta a Incidentes	61
7.1 Metodología de gestión de riesgos	61
7.2 Matriz de riesgos	62
7.3 Plan de Respuesta a Incidentes Simplificado	64
7.3.1 Fases del IRP.....	64
7.4 Roles esenciales del CSIRT interno	65
7.5 Clasificación de severidad de incidentes	66
7.6 Acciones inmediatas ante incidente crítico	66
7.7 KPIs y KRIs de gestión	66
7.8 Conclusión del módulo.....	67
Enlace del Repositorio	68
Referencias Bibliográficas	69

MÓDULO 1. Panorama de Amenazas y Relación con el Caso

1.1 Introducción

El Instituto Tecnológico CREATIC atraviesa un proceso de transformación digital que ha incrementado significativamente su superficie de exposición frente a amenazas cibernéticas. La adopción de un modelo híbrido de trabajo, el uso de dispositivos personales (BYOD), la dependencia de servicios en la nube y la coexistencia de infraestructura local (On-Premises) generan un entorno altamente distribuido donde el modelo tradicional de seguridad basado únicamente en el perímetro deja de ser suficiente.

Esta situación se agrava debido a las debilidades descritas en el caso de estudio: credenciales administrativas comprometidas, campañas exitosas de spear phishing, servidores sin actualizaciones de seguridad, configuraciones inseguras y una red completamente plana que facilita el movimiento lateral de un atacante. Con el propósito de establecer una línea base para el diseño de la nueva arquitectura de seguridad, en este módulo se analizan las principales amenazas observadas durante el periodo 2025–2026 utilizando como referencia el Mandiant M-Trends Report 2026, complementado con las recomendaciones emitidas por la Cybersecurity and Infrastructure Security Agency (CISA).

1.2 Panorama actual de amenazas

El panorama global de amenazas continúa evolucionando hacia ataques cada vez más rápidos, automatizados y coordinados. El Mandiant M-Trends 2026, elaborado a partir de más de 500 000 horas de investigaciones reales de respuesta a incidentes, evidencia que los atacantes han reducido drásticamente el tiempo entre la obtención del acceso inicial y el inicio de acciones maliciosas dentro de la infraestructura comprometida (Mandiant, 2026, p. 4). En algunos casos analizados, el traspaso del acceso entre grupos criminales especializados ocurre en apenas 22 segundos, lo que reduce considerablemente la capacidad de reacción de las organizaciones (Mandiant, 2026, p. 55).

El informe también destaca que la explotación de vulnerabilidades continúa siendo el principal vector de acceso inicial por sexto año consecutivo. Paralelamente, aumentan las campañas de ingeniería social altamente personalizadas, el robo de credenciales, el abuso de servicios en la nube, el compromiso de proveedores externos y la utilización de herramientas legítimas del propio sistema operativo para evadir mecanismos tradicionales de detección. Otro cambio importante identificado por Mandiant corresponde a la evolución del ransomware. Los grupos criminales ya no limitan sus acciones al cifrado de archivos, sino que buscan impedir deliberadamente la recuperación de los sistemas destruyendo copias de seguridad, comprometiendo servicios de identidad y atacando plataformas de virtualización antes de ejecutar el proceso de cifrado. Este enfoque, denominado Recovery Denial, incrementa significativamente el impacto operativo y económico de los incidentes. (Mandiant, 2026, p. 5).

Por su parte, CISA señala que la mayoría de los incidentes exitosos siguen aprovechando problemas básicos de seguridad: autenticación débil, sistemas desactualizados, configuraciones inseguras, privilegios excesivos y falta de segmentación de red. En consecuencia, la agencia recomienda adoptar

arquitecturas Zero Trust, autenticación multifactor (MFA), monitoreo continuo, gestión rigurosa de identidades y políticas de mínimo privilegio como pilares fundamentales para reducir el riesgo organizacional (CISA, 2022, p. 2).

Desde una perspectiva técnica, estas tendencias son especialmente relevantes para CREATIC porque la institución presenta simultáneamente tres condiciones de alto riesgo: credenciales expuestas, acceso remoto débil y ausencia de segmentación interna. Esto significa que un atacante no necesita explotar una vulnerabilidad compleja para iniciar el compromiso; podría autenticarse con credenciales válidas, ingresar por la VPN tradicional y desplazarse lateralmente dentro de la red debido a la falta de controles internos. Por tanto, el análisis de amenazas no debe entenderse únicamente como una descripción general del panorama global, sino como una justificación directa para adoptar una arquitectura basada en Zero Trust, monitoreo continuo y defensa en profundidad.

1.3 Relación de las amenazas con el caso CREATIC

El análisis del caso permite identificar una correspondencia directa entre las amenazas descritas por Mandiant y las vulnerabilidades presentes en CREATIC.

1.3.1 Spear Phishing

Durante el periodo operativo 2025–2026, CREATIC sufrió campañas exitosas de spear phishing dirigidas al personal docente. Este tipo de ataque constituye uno de los mecanismos más efectivos para obtener credenciales válidas mediante mensajes cuidadosamente diseñados para generar confianza en la víctima.

El riesgo resulta especialmente elevado debido a que aproximadamente 250 docentes contratistas utilizan equipos personales bajo un esquema BYOD, lo que dificulta la aplicación homogénea de controles de seguridad y aumenta la probabilidad de compromiso de cuentas institucionales.

Una vez obtenidas las credenciales, el atacante podría acceder a servicios académicos, plataformas SaaS o conexiones remotas utilizando credenciales legítimas, evitando inicialmente los mecanismos tradicionales de detección.

1.3.2 Credential Stuffing

El caso establece que credenciales administrativas fueron encontradas en la Dark Web.

Esta situación representa un escenario ideal para ataques de **Credential Stuffing**, técnica mediante la cual los atacantes reutilizan automáticamente combinaciones de usuario y contraseña filtradas para intentar acceder a múltiples servicios corporativos.

La infraestructura actual agrava este riesgo debido a que el acceso remoto utiliza una VPN tradicional protegida únicamente mediante usuario y contraseña, sin autenticación multifactor ni evaluación del estado de seguridad del dispositivo.

En consecuencia, un atacante podría acceder a la red institucional utilizando credenciales legítimas sin necesidad de explotar vulnerabilidades adicionales.

1.3.3 Movimiento lateral

Uno de los riesgos más críticos identificados en CREATIC corresponde a la inexistencia de segmentación de red. Actualmente, los principales servidores de la organización comparten un mismo entorno lógico o mantienen comunicación interna sin controles estrictos de aislamiento. Esto incluye al Controlador de Dominio (CR-DC-01), el Servidor Web del Portal Académico (CR-APPSRV-02), la Base de Datos de calificaciones y finanzas (CR-DB-01) y el Servidor de Archivos administrativos (CR-FILE-03).

En este escenario, el compromiso inicial de un solo activo podría transformarse rápidamente en un incidente de alcance institucional. Por ejemplo, si un atacante obtiene acceso al servidor web CR-APPSRV-02 mediante credenciales robadas, una vulnerabilidad de aplicación o una conexión SSH insegura, podría intentar conectarse posteriormente hacia CR-DB-01 para extraer información académica y financiera. De igual forma, podría buscar credenciales en memoria, reutilizar cuentas válidas o intentar acceder a recursos compartidos en CR-FILE-03.

Desde la perspectiva de MITRE ATT&CK, esta situación favorece técnicas como el uso de cuentas válidas, servicios remotos, Pass-the-Hash, abuso de SMB, ejecución de comandos y credential dumping. La ausencia de microsegmentación convierte un incidente inicialmente localizado en un compromiso potencial de toda la infraestructura, afectando directamente la confidencialidad, integridad y disponibilidad de los activos críticos de CREATIC.

Por esta razón, el movimiento lateral representa uno de los principales argumentos técnicos para sustituir la red plana por VLANs, controles de acceso entre segmentos, monitoreo de tráfico interno y políticas de mínimo privilegio.

1.3.4 Ransomware

El caso menciona incidentes previos de ransomware en equipos remotos. El impacto potencial aumenta debido a la combinación de múltiples vulnerabilidades:

- SMBv1 habilitado.
- Sistemas sin actualización durante seis meses.
- Ausencia de EDR.
- Antivirus tradicional basado únicamente en firmas.
- Permisos excesivos sobre carpetas compartidas.
- Ausencia de monitoreo centralizado.

En estas condiciones, un atacante podría cifrar simultáneamente múltiples servidores, comprometer el Directorio Activo y afectar la continuidad de las operaciones académicas y administrativas.

1.3.5 Explotación de aplicaciones vulnerables

El Portal Académico se encuentra alojado sobre Apache en Debian 11 y permite autenticación directa del usuario root mediante SSH utilizando contraseña.

Además, los despliegues se realizan manualmente mediante FTP/SCP sin controles automáticos de revisión de código.

Esta situación incrementa el riesgo de:

- Ejecución remota de código (RCE).
- Compromiso de credenciales.
- Alteración del código fuente.
- Inserción de puertas traseras (Backdoors).
- Ataques a la cadena de suministro de software.

1.3.6 Ruta de ataque probable en CREATIC

Con base en las debilidades identificadas en el caso, se puede establecer una ruta de ataque probable que demuestra cómo un incidente aparentemente aislado podría escalar hasta comprometer activos críticos de la institución.

La secuencia más probable sería la siguiente:

1. Un docente contratista recibe un correo de spear phishing diseñado para simular una comunicación institucional legítima.
2. El usuario entrega sus credenciales o accede a un enlace malicioso desde un equipo personal bajo modalidad BYOD.
3. El atacante reutiliza las credenciales obtenidas para acceder a servicios institucionales o a la VPN tradicional, la cual no cuenta con MFA ni validación de postura del dispositivo.
4. Una vez dentro de la red, el atacante explora los segmentos internos debido a la ausencia de VLANs y microsegmentación.
5. El atacante identifica el servidor web CR-APPSRV-02 y aprovecha configuraciones débiles, como SSH expuesto, autenticación por contraseña o servicios sin hardening.
6. Desde el servidor web, intenta conectarse hacia CR-DB-01 para acceder a calificaciones, información financiera y datos personales.
7. Posteriormente, busca escalar privilegios hacia CR-DC-01 para comprometer el dominio o acceder al servidor CR-FILE-03 para cifrar o exfiltrar documentos administrativos.
8. Finalmente, el atacante puede ejecutar ransomware, exfiltrar información o mantener persistencia dentro de la infraestructura.

Esta ruta de ataque evidencia que las amenazas de phishing avanzado, credential stuffing y movimiento lateral no son eventos independientes, sino fases encadenadas de un mismo escenario de compromiso. Por ello, la respuesta técnica del proyecto debe integrar controles preventivos, detectivos y correctivos: MFA, ZTNA, microsegmentación, hardening de servidores, monitoreo SIEM/EDR y respuesta a incidentes.

1.4 Mapeo de amenazas utilizando MITRE ATT&CK

Para complementar el análisis de amenazas identificado en CREATIC, se utiliza la matriz MITRE ATT&CK como marco de referencia técnico para relacionar las amenazas observadas con tácticas y técnicas empleadas por adversarios reales.

Este mapeo permite comprender cómo ataques como spear phishing, credential stuffing, uso de cuentas válidas, movimiento lateral y ransomware podrían

materializarse dentro de la infraestructura actual de la institución. Además, facilita la identificación de controles de seguridad necesarios para reducir la probabilidad de compromiso y limitar el impacto sobre los activos críticos.

Amenaza observada	Técnica MITRE ATT&CK	Descripción aplicada a CREATIC	Activo relacionado
Spear Phishing	T1566.001 / T1566.002 - Spearphishing Attachment / Spearphishing Link	Envío de correos dirigidos a docentes o administrativos para obtener credenciales institucionales o inducir la ejecución de contenido malicioso.	Cuentas docentes, SaaS, VPN, Portal Académico
Credential Stuffing	T1110.004 - Credential Stuffing	Reutilización automatizada de credenciales administrativas expuestas en la Dark Web contra servicios institucionales.	VPN, CR-DC-01, aplicaciones institucionales
Valid Accounts	T1078 - Valid Accounts	Uso de cuentas legítimas comprometidas para evadir controles tradicionales de seguridad y acceder a recursos internos.	CR-DC-01, VPN, servicios internos
Credential Dumping	T1003 - OS Credential Dumping	Extracción de credenciales o hashes desde equipos o servidores comprometidos para escalar privilegios.	CR-DC-01, CR-FILE-03
Remote Services	T1021 - Remote Services	Uso de servicios remotos para desplazarse entre servidores una vez obtenido el acceso inicial.	CR-APPSRV-02, CR-DB-01, CR-FILE-03
Pass-the-Hash	T1550.002 - Pass the Hash	Reutilización de hashes de credenciales para autenticarse en sistemas Windows sin conocer la contraseña en texto claro.	CR-DC-01, CR-FILE-03
Command and Scripting Interpreter	T1059 - Command and Scripting Interpreter	Ejecución de comandos para automatizar reconocimiento, persistencia, descarga de herramientas o movimiento lateral.	Servidores Windows y Linux
Exfiltration Over C2 Channel	T1041 - Exfiltration Over C2 Channel	Extracción de información académica, financiera o administrativa hacia infraestructura controlada por el atacante.	CR-DB-01, CR-FILE-03
Data Encrypted for Impact	T1486 - Data Encrypted for Impact	Cifrado de archivos y servicios críticos durante un ataque de ransomware.	CR-FILE-03, CR-DB-01, endpoints administrativos

Tabla 1. Mapeo de Amenazas identificadas en CREATIC.

Este mapeo demuestra que las debilidades presentes en CREATIC se alinean con técnicas reales utilizadas por adversarios modernos. En particular, el uso de credenciales válidas, la ausencia de MFA, la red plana y la falta de monitoreo centralizado aumentan la probabilidad de que un atacante avance desde el acceso inicial hasta la exfiltración de datos o la interrupción operativa.

Por tanto, la arquitectura propuesta en los módulos siguientes debe enfocarse en reducir la superficie de ataque, limitar el movimiento lateral y mejorar la capacidad de detección temprana.

1.5 Evaluación de impacto sobre la Triada CIA

Activo	Confidencialidad	Integridad	Disponibilidad	Justificación
CR-DC-01	Muy Alta	Muy Alta	Muy Alta	Es el Controlador de Dominio y administra autenticación, DNS, DHCP y políticas del entorno. Su compromiso permitiría al atacante controlar cuentas, modificar privilegios, acceder a servidores internos y mantener persistencia dentro de la organización.
CR-APPSRV-02	Alta	Muy Alta	Alta	Aloja el Portal Académico, principal servicio expuesto a usuarios internos y externos. Una vulnerabilidad en este servidor podría permitir alteración del portal, ejecución remota de código, robo de credenciales o pivote hacia la base de datos.
CR-DB-01	Crítica	Crítica	Alta	Contiene calificaciones, información financiera y datos personales protegidos por la Ley 81. Su compromiso

				afectaría directamente la confidencialidad de los titulares, la integridad de los registros académicos y financieros, y la continuidad de servicios esenciales.
CR-FILE-03	Alta	Alta	Alta	Almacena documentos administrativos y presenta permisos excesivos para el grupo "Everyone". En caso de ransomware, exfiltración o modificación no autorizada, se afectaría la disponibilidad de documentos críticos y la integridad de los procesos administrativos.

Tabla 2. Evaluación de Impacto de activos.

El activo más crítico corresponde a CR-DB-01, debido a que concentra información académica, financiera y datos personales. Una brecha sobre este sistema comprometería la confidencialidad de los titulares de los datos, la integridad de las calificaciones y registros financieros, así como la disponibilidad de servicios esenciales para estudiantes, docentes y personal administrativo. Además, este activo tiene implicaciones legales directas bajo la Ley 81 de Protección de Datos Personales.

El segundo activo de mayor criticidad es CR-DC-01, ya que representa el núcleo de identidad de la organización. Si un atacante compromete el Controlador de Dominio, podría crear usuarios privilegiados, modificar políticas de seguridad, acceder a recursos compartidos y mantener persistencia dentro del entorno. Por esta razón, cualquier incidente sobre CR-DC-01 debe considerarse de impacto institucional.

CR-APPSRV-02 también representa un punto de alto riesgo porque funciona como puerta de entrada hacia los servicios académicos. Al estar expuesto y presentar debilidades como SSH abierto, autenticación por contraseña y ausencia de controles automatizados de seguridad en el desarrollo, puede convertirse en el punto inicial de una cadena de compromiso.

Finalmente, CR-FILE-03 debe considerarse crítico para la continuidad administrativa. Aunque su función no es transaccional como la base de datos,

los permisos laxos y la exposición del grupo “Everyone” incrementan el riesgo de acceso no autorizado, fuga de información o cifrado masivo de documentos durante un ataque de ransomware.

1.5.1 Impacto directo de las amenazas principales

Amenaza	Vector de entrada	Activo afectado	Impacto CIA	Consecuencia para CREATIC
Spear Phishing	Correo dirigido a docentes o administrativos	Cuentas institucionales, Portal Académico, SaaS	Confidencialidad e Integridad	Robo de credenciales, acceso no autorizado y posible manipulación de información académica.
Credential Stuffing	Reutilización de credenciales filtradas	VPN, CR-DC-01, servicios internos	Confidencialidad, Integridad y Disponibilidad	Acceso no autorizado con credenciales válidas, evasión de controles tradicionales y escalamiento de privilegios.
Movimiento lateral	Red plana sin VLANs ni microsegmentación	CR-APPSRV-02, CR-DB-01, CR-FILE-03, CR-DC-01	Confidencialidad, Integridad y Disponibilidad	Propagación del ataque desde un servidor comprometido o hacia activos críticos.
Ransomware	Endpoint remoto comprometido, SMBv1, permisos excesivos	CR-FILE-03, CR-DB-01, endpoints administrativos	Disponibilidad e Integridad	Cifrado de información, interrupción operativa y posible pérdida de datos.
Explotación de aplicación vulnerable	Portal Académico o librerías inseguras	CR-APPSRV-02, CR-DB-01	Integridad y Confidencialidad	Ejecución remota de código, alteración del portal y acceso no

				autorizado a la base de datos.
--	--	--	--	--------------------------------

Tabla 3. Impacto de Amenazas Principales Observadas.

1.6 Conclusión del módulo

El análisis del panorama de amenazas demuestra que CREATIC se encuentra expuesto a escenarios de alto impacto debido a la combinación de credenciales comprometidas, autenticación débil, ausencia de MFA, red plana, servidores sin hardening, permisos excesivos y falta de monitoreo centralizado. Estas condiciones permiten que amenazas como spear phishing, credential stuffing, movimiento lateral, explotación de aplicaciones vulnerables y ransomware puedan encadenarse dentro de una misma ruta de ataque.

Desde la perspectiva de la triada CIA, los activos más sensibles son CR-DB-01 y CR-DC-01. El primero concentra datos académicos, financieros y personales protegidos por la Ley 81, mientras que el segundo controla la identidad y autenticación de la infraestructura. CR-APPSRV-02 representa el principal punto de exposición hacia usuarios y servicios externos, y CR-FILE-03 constituye un activo crítico para la continuidad administrativa por sus permisos laxos y exposición a ransomware.

Por tanto, este módulo justifica técnicamente la necesidad de rediseñar la seguridad institucional bajo un enfoque de Zero Trust y Defensa en Profundidad. Los controles propuestos en los módulos siguientes deberán enfocarse en verificar continuamente la identidad del usuario, limitar privilegios, segmentar la red, endurecer servidores, monitorear eventos de seguridad y preparar una respuesta efectiva ante incidentes.

MÓDULO 2. Arquitectura de Red Moderna basada en Zero Trust y SASE

2.1 Diagnóstico de la arquitectura actual (Estado AS-IS)

La infraestructura tecnológica actual del Instituto Tecnológico CREATIC fue diseñada bajo un modelo tradicional de seguridad perimetral, donde la protección depende principalmente de un firewall Stateful ubicado en el borde de la red. Este enfoque asume que todos los usuarios y dispositivos ubicados dentro de la red institucional son confiables, una premisa que resulta incompatible con el contexto operativo actual de la organización, caracterizado por el acceso remoto, el uso de dispositivos personales (BYOD) y la utilización de aplicaciones en la nube.

El análisis de la infraestructura revela múltiples debilidades que incrementan significativamente la superficie de ataque y facilitan la propagación de incidentes de seguridad.

Entre las principales vulnerabilidades identificadas destacan:

- Red completamente plana sin segmentación mediante VLANs.
- Firewall tradicional sin capacidades de inspección de capa 7 ni prevención de intrusiones (IPS).
- Acceso remoto mediante VPN PPTP/L2TP basado únicamente en usuario y contraseña.
- Ausencia de autenticación multifactor (MFA).

- Falta de validación del estado de seguridad de los dispositivos antes de conceder acceso.
- Inexistencia de políticas de mínimo privilegio entre servidores.
- Comunicación directa entre el servidor web y la base de datos sin controles de aislamiento.
- Dispositivos BYOD sin ningún mecanismo de supervisión o cumplimiento de políticas institucionales.

Como consecuencia, un atacante que logre comprometer un único equipo mediante phishing o robo de credenciales podría desplazarse lateralmente hacia servidores críticos sin encontrar controles efectivos que limiten su alcance.

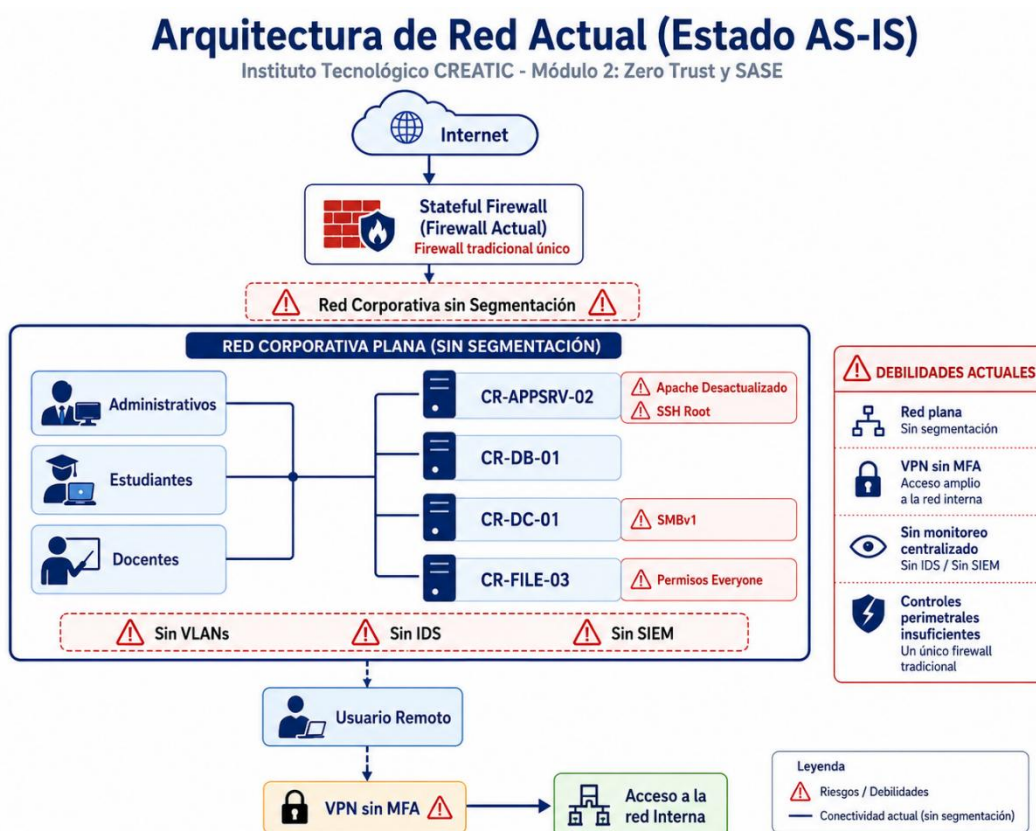


Figura 1. Arquitectura de red actual (Estado AS-IS)

2.2 Limitaciones del modelo de seguridad tradicional

La arquitectura actual responde al paradigma conocido como **Castle-and-Moat** (castillo y foso), donde el firewall representa la principal barrera de protección mientras que todos los recursos internos se consideran confiables una vez superado el perímetro.

Este enfoque presenta importantes limitaciones frente al panorama actual de amenazas.

En primer lugar, la organización ya no opera exclusivamente desde el campus universitario. Los docentes acceden diariamente desde redes domésticas, dispositivos personales y plataformas SaaS, lo que elimina la noción de un perímetro claramente definido.

En segundo lugar, el compromiso de una única cuenta administrativa permitiría al atacante acceder libremente a diferentes activos debido a la ausencia de segmentación y controles de acceso basados en identidad.

El modelo actual dificulta la detección temprana de movimientos laterales y no contempla la verificación continua del estado de seguridad de los dispositivos conectados a la red.

Por estas razones, mantener el enfoque tradicional incrementa el riesgo operativo, financiero y reputacional para la institución.

Adicionalmente, el modelo actual no permite aplicar controles diferenciados según el nivel de riesgo del usuario, el dispositivo o el recurso solicitado. En una arquitectura moderna, un docente conectado desde un equipo personal, un administrador de TI y un estudiante no deben recibir el mismo nivel de acceso a la red interna. La ausencia de esta diferenciación incrementa el riesgo de abuso de credenciales, propagación de malware y acceso no autorizado a sistemas críticos.

Por esta razón, la propuesta de modernización debe abandonar la confianza implícita del modelo perimetral y adoptar un enfoque basado en identidad, contexto, mínimo privilegio, segmentación y monitoreo continuo. Este enfoque se alinea con los principios de Zero Trust y permite avanzar hacia una arquitectura SASE gradual, adaptada a la restricción presupuestaria de CREATIC.

2.3 Propuesta de Arquitectura Zero Trust

Con el propósito de reducir la superficie de ataque y fortalecer la resiliencia de la infraestructura, se propone adoptar una arquitectura basada en el modelo **Zero Trust**, definido por el NIST como un paradigma donde ningún usuario, dispositivo o aplicación recibe confianza implícita, independientemente de su ubicación dentro o fuera de la red.

En lugar de asumir que los usuarios internos son confiables, cada solicitud de acceso deberá ser autenticada, autorizada y validada continuamente considerando múltiples factores, entre ellos:

- Identidad del usuario.
- Estado del dispositivo.
- Nivel de privilegio requerido.
- Ubicación del acceso.
- Nivel de riesgo de la sesión.
- Sensibilidad del recurso solicitado.

Bajo este enfoque, el acceso a los recursos institucionales deja de depender de la ubicación física del usuario y pasa a depender de su identidad y del cumplimiento de políticas de seguridad previamente definidas.

2.4 Arquitectura propuesta (Estado TO-BE)

La arquitectura propuesta incorpora controles de seguridad distribuidos en múltiples capas siguiendo el principio de Defensa en Profundidad.

Los componentes principales serán los siguientes:

Capa de seguridad	Tecnología propuesta	Función dentro de CREATIC
Firewall perimetral / control inter-VLAN	pfSense Community Edition	Control de tráfico perimetral, NAT, reglas entre VLANs, filtrado de tráfico, bloqueo de IPs maliciosas y envío de logs hacia Wazuh.
IDS/IPS	Suricata integrado con pfSense	Detección y prevención de intrusiones mediante firmas, análisis de tráfico sospechoso y generación de alertas de seguridad.
Web Application Firewall	ModSecurity + OWASP Core Rule Set	Protección del Portal Académico contra ataques web como SQL Injection, XSS, CSRF, manipulación de parámetros y solicitudes maliciosas HTTP/HTTPS.
Acceso remoto Zero Trust	Headscale + cliente compatible con Tailscale/WireGuard	Sustitución de la VPN tradicional por acceso basado en identidad, dispositivo autorizado y recurso específico.
Gestión de identidad y MFA	Keycloak + TOTP/FIDO2	Autenticación centralizada, integración con MFA y control de acceso basado en roles.
Microsegmentación	VLANs dedicadas y reglas de mínimo privilegio	Separación lógica de usuarios, servidores, base de datos, DMZ, BYOD, backups y administración para limitar movimiento lateral.
Monitoreo y respuesta	Wazuh SIEM/EDR	Centralización de logs, correlación de eventos, detección de amenazas y soporte al SOC conceptual.
Administración segura	VLAN de Gestión	Acceso administrativo restringido únicamente a personal de TI autorizado mediante MFA y dispositivos confiables.
Protección de datos	Segmento aislado para CR-DB-01 y backups	Reducción del riesgo de acceso directo a datos académicos, financieros y personales protegidos por la Ley 81.

Tabla 4. Elementos de la arquitectura de red propuesta

La arquitectura propuesta establece controles distribuidos en varias capas, de forma que la seguridad no dependa únicamente del firewall perimetral. Cada solicitud de acceso será evaluada en función de la identidad del usuario, la postura del dispositivo, el recurso solicitado y el nivel de criticidad del activo.

De esta manera, incluso si un atacante compromete una cuenta o un equipo, la microsegmentación, el acceso mínimo necesario y el monitoreo continuo limitarán su capacidad de desplazarse lateralmente dentro de la infraestructura.

Nota técnica sobre la solución NGFW propuesta:

Debido a que el proyecto establece una restricción presupuestaria de USD \$0 para licencias comerciales, no se propone adquirir soluciones propietarias como Palo Alto, Fortinet o Check Point. En su lugar, se plantea una arquitectura tipo NGFW basada en pfSense Community Edition, complementada con Suricata para IDS/IPS, reglas estrictas inter-VLAN, filtrado DNS, listas de bloqueo y registro centralizado de eventos. Aunque esta alternativa no ofrece todas las capacidades avanzadas de un NGFW comercial, sí permite implementar controles modernos de inspección, segmentación, prevención de intrusiones y visibilidad operativa, manteniendo la viabilidad económica del proyecto.

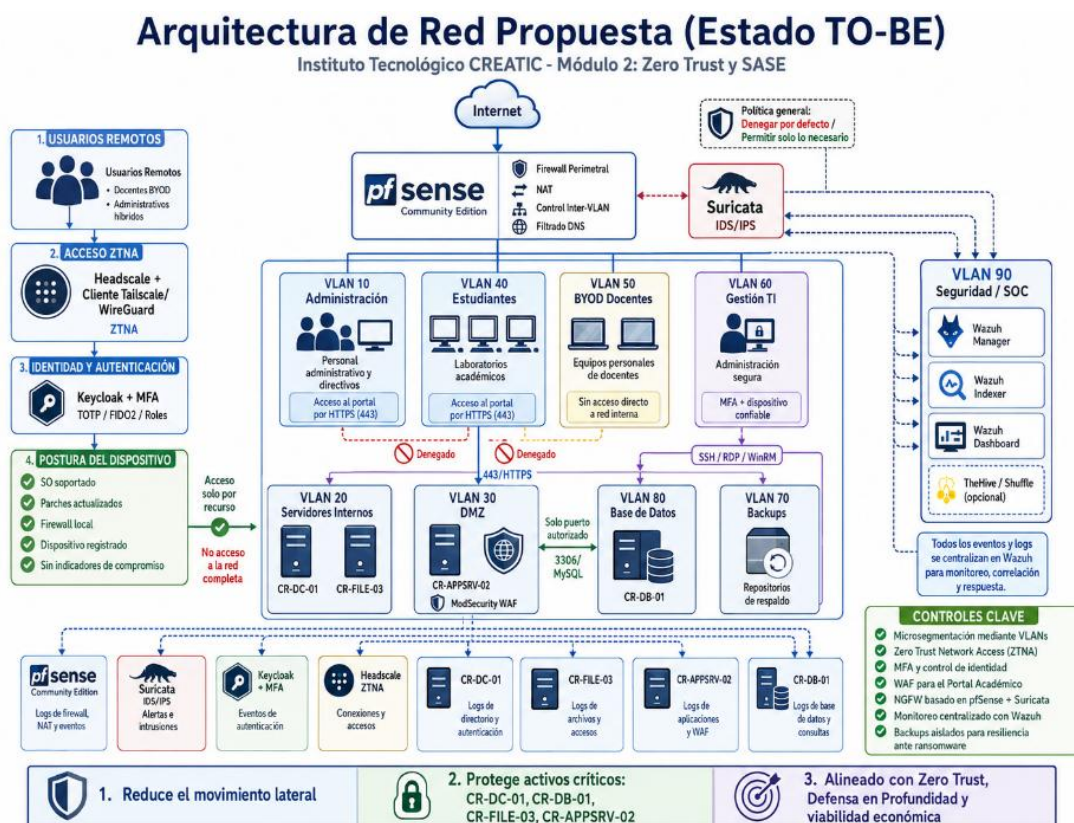


Figura 2. Arquitectura de red propuesta (Estado TO-BE).

2.5 Diseño de la Microsegmentación

Con el fin de minimizar el movimiento lateral y aplicar políticas de mínimo privilegio, la infraestructura será dividida en VLANs independientes.

VLAN	Nombre	Recursos incluidos	Objetivo de seguridad
VLAN 10	Administración	Personal administrativo y directivos	Separar usuarios administrativos de estudiantes, BYOD y servidores críticos.
VLAN 20	Servidores internos	CR-DC-01, CR-FILE-03	Proteger servicios internos de dominio, archivos y administración institucional.
VLAN 30	DMZ	CR-APPSRV-02, WAF ModSecurity	Aislar el Portal Académico expuesto a usuarios internos y externos.
VLAN 40	Estudiantes	Laboratorios académicos y equipos de estudiantes	Permitir acceso únicamente a servicios académicos autorizados.
VLAN 50	BYOD Docentes	Equipos personales de docentes contratistas	Restringir acceso directo a la red interna y obligar el uso de ZTNA.
VLAN 60	Gestión TI	Equipos de administradores, consola de administración, acceso remoto seguro	Limitar tareas administrativas a personal autorizado con MFA.
VLAN 70	Backups	Servidores de respaldo y almacenamiento	Proteger respaldos contra ransomware y accesos no autorizados.
VLAN 80	Base de Datos	CR-DB-01	Aislar datos académicos, financieros y personales protegidos por Ley 81.
VLAN 90	Seguridad SOC	Wazuh Manager, Wazuh Indexer, Wazuh Dashboard, TheHive/Shuffle si aplica	Centralizar monitoreo, correlación de eventos y respuesta a incidentes.

Tabla 5. VLANs resultantes de la segmentación de red.

Esta segmentación permite aplicar el principio de mínimo privilegio a nivel de red. Cada VLAN tendrá reglas específicas de entrada y salida, evitando que los usuarios o servidores tengan comunicación amplia por defecto.

La política general será “denegar todo y permitir únicamente lo necesario”, de forma que cualquier comunicación entre segmentos deba estar justificada por una necesidad operativa.

La separación lógica permitirá definir reglas específicas de comunicación entre segmentos.

Por ejemplo:

- La VLAN de estudiantes no tendrá comunicación directa con los servidores administrativos.
- Los dispositivos BYOD únicamente podrán acceder a los servicios estrictamente autorizados mediante Zero Trust Network Access (ZTNA).
- El servidor web ubicado en la DMZ podrá comunicarse únicamente con la base de datos utilizando los puertos requeridos por la aplicación.
- Ningún equipo de usuario tendrá acceso directo al Controlador de Dominio.

Este diseño reduce considerablemente la propagación de malware y limita la capacidad de movimiento lateral.

2.6 Implementación de NGFW y WAF

El firewall perimetral será reemplazado por una solución **Next-Generation Firewall (NGFW)** basada en **pfSense Community Edition**, complementada con **Suricata** como motor de detección y prevención de intrusiones.

Las principales funcionalidades implementadas serán:

- Inspección profunda de paquetes (Deep Packet Inspection).
- Filtrado de aplicaciones por capa 7.
- IDS/IPS mediante firmas actualizadas.
- GeoIP Blocking para restringir conexiones desde regiones no autorizadas.
- Filtrado DNS.
- Control de tráfico entre VLANs.
- Registro centralizado de eventos hacia Wazuh.

Esta solución permitirá identificar comportamientos anómalos que actualmente pasan desapercibidos por el firewall tradicional.

Como complemento al NGFW, se propone también la implementación de un **Web Application Firewall (WAF)** para proteger las aplicaciones web institucionales y servicios accesibles por estudiantes, docentes y personal administrativo.

El WAF proporciona una capa adicional de protección enfocada en el tráfico HTTP y HTTPS. La solución propuesta consiste en implementar **ModSecurity** como motor WAF, integrado con el servidor web y configurado con el **OWASP Core Rule Set (CRS)**.

Las principales funcionalidades implementadas serán:

- Protección contra ataques de Inyección SQL
- Detección y bloqueo de ataques Cross-Site Scripting (XSS)
- Prevención de ataques de Cross-Site Request Forgery (CSRF)
- Validación de encabezados HTTP, parámetros y cookies

- Registro detallado de eventos y envío de alertas al SIEM Wazuh para su correlación y análisis.

Igualmente, el WAF contribuirá a disminuir la superficie de ataque de los servicios DMZ, impidiendo que solicitudes maliciosas alcancen los servidores de aplicaciones y las bases de datos institucionales.

Control	Implementación	Resultado esperado
Inspección de tráfico	Suricata en pfSense	Detectar patrones de ataque, escaneos, exploits conocidos y tráfico sospechoso.
Control inter-VLAN	Reglas explícitas en pfSense	Evitar comunicación no autorizada entre estudiantes, BYOD, servidores, base de datos y backups.
GeolP Blocking	Listas de bloqueo en pfSense	Reducir exposición a conexiones desde regiones no requeridas por la operación.
Filtrado DNS	pfSense / pfBlockerNG o listas DNS	Bloquear dominios maliciosos, phishing y destinos de comando y control conocidos.
WAF	ModSecurity + OWASP CRS	Proteger el Portal Académico contra SQL Injection, XSS, CSRF y manipulación de parámetros.
Registro centralizado	Envío de logs a Wazuh	Permitir correlación de eventos y detección temprana de incidentes.

Tabla 6. Controles implementados y resultados esperados.

El NGFW y el WAF cumplen funciones complementarias. El NGFW controla el tráfico de red, segmenta la comunicación entre VLANs y detecta amenazas a nivel de paquetes y conexiones.

El WAF, por su parte, protege específicamente la capa de aplicación web, analizando solicitudes HTTP/HTTPS antes de que lleguen al Portal Académico. Esta combinación fortalece la defensa en profundidad y reduce la probabilidad de que un ataque web se convierta en un compromiso de infraestructura.

2.7 Migración de VPN Tradicional a ZTNA

El acceso remoto basado en PPTP/L2TP será reemplazado por un modelo Zero Trust Network Access (ZTNA), utilizando Headscale como servidor de control open source y clientes compatibles con Tailscale/WireGuard para establecer conexiones cifradas entre dispositivos autorizados y recursos específicos.

A diferencia de una VPN tradicional, donde el usuario autenticado puede obtener visibilidad amplia de la red interna, ZTNA concede acceso únicamente al recurso necesario, durante el tiempo necesario y bajo condiciones previamente validadas. Esto reduce el riesgo de movimiento lateral en caso de robo de credenciales o compromiso de un equipo remoto.

El modelo propuesto se basa en los siguientes principios:

1. Ningún usuario o dispositivo recibe confianza implícita.

2. Todo acceso requiere autenticación fuerte mediante MFA.
3. El dispositivo debe estar registrado y cumplir criterios mínimos de postura.
4. El acceso se concede por aplicación o recurso, no por red completa.
5. Las sesiones se registran y envían al SIEM para auditoría.
6. Los permisos se asignan según roles y principio de mínimo privilegio.

Para CREATIC, este cambio es especialmente importante porque los docentes contratistas utilizan dispositivos BYOD y los administrativos trabajan bajo modalidad híbrida. Con ZTNA, estos usuarios no acceden directamente a toda la red interna, sino únicamente a los servicios autorizados, como el Portal Académico o recursos específicos según su rol.

2.8 Flujo de autenticación con MFA

El proceso de autenticación propuesto integra identidad, segundo factor, validación del dispositivo y autorización por recurso. Este flujo permite eliminar la confianza implícita y aplicar verificación continua antes de conceder acceso.

Paso	Componente	Acción	Resultado
1	Usuario remoto	Solicita acceso a un recurso institucional.	Inicio de sesión de acceso.
2	Headscale / ZTNA	Verifica que el dispositivo esté registrado y autorizado.	El dispositivo pasa a evaluación de identidad.
3	Keycloak	Solicita usuario y contraseña institucional.	Validación inicial de identidad.
4	Keycloak MFA	Solicita segundo factor TOTP, FIDO2 o aplicación autenticadora.	Confirmación de identidad fuerte.
5	Evaluación de postura	Revisa sistema operativo, parches, firewall local, antivirus y cliente ZTNA.	Determina si el dispositivo es confiable.
6	Motor de políticas	Evalúa rol del usuario, recurso solicitado y nivel de riesgo.	Autoriza, restringe o deniega el acceso.
7	Recurso autorizado	Se permite acceso únicamente al servicio requerido.	Acceso mínimo necesario.
8	Wazuh SIEM	Registra autenticación, resultado MFA, dispositivo, IP origen y recurso accedido.	Trazabilidad y monitoreo continuo.

Tabla 7. Proceso de autenticación con MFA

Flujo de Autenticación ZTNA con MFA

Instituto Tecnológico CREATIC - Módulo 2: Zero Trust y SASE

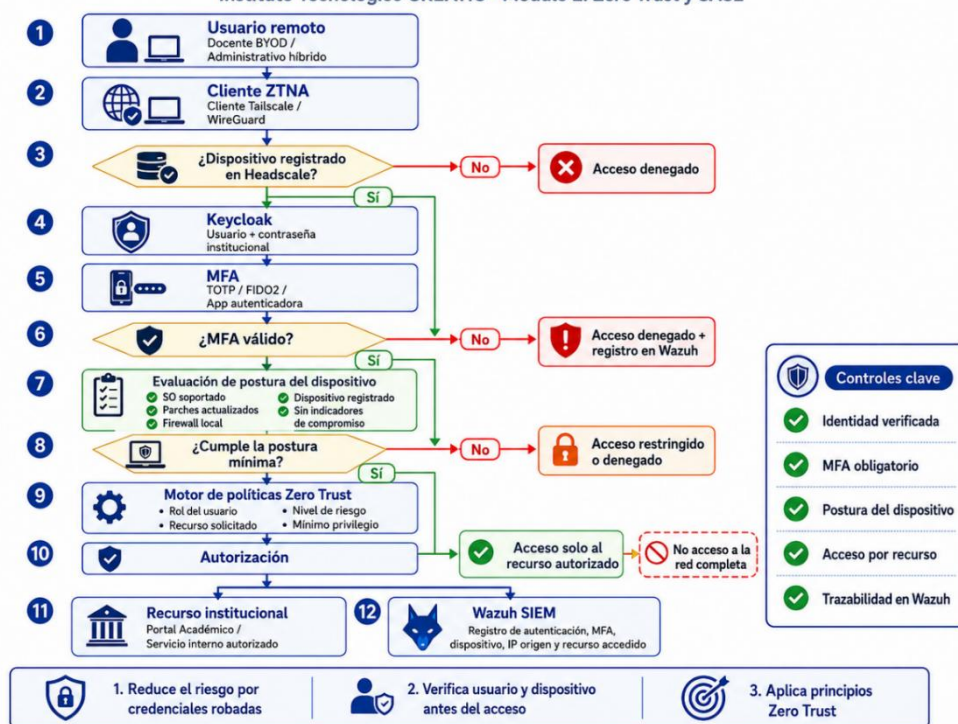


Figura 3. Flujo de autenticación ZTNA con MFA

Este flujo garantiza que el acceso no dependa únicamente de la contraseña. Un atacante que posea credenciales válidas no podrá ingresar si no supera el segundo factor de autenticación, si el dispositivo no está registrado o si no cumple los criterios mínimos de postura.

Además, cada intento exitoso o fallido queda registrado para fines de auditoría y respuesta ante incidentes.

2.9 Evaluación de la postura del dispositivo

Antes de permitir el acceso a recursos institucionales, cada dispositivo deberá cumplir una serie de controles mínimos de seguridad:

Control evaluado	Estado requerido	Método de validación	Acción si no cumple
Sistema operativo soportado	Obligatorio	Verificación del sistema reportado por el cliente ZTNA o registro del dispositivo.	Denegar acceso a recursos internos.
Parches de seguridad actualizados	Obligatorio	Validación de versión del sistema y fecha de actualización declarada o gestionada.	Restringir acceso hasta remediación.
Antivirus o protección	Obligatorio para equipos	Validación por agente institucional o	Restringir acceso a

endpoint activa	institucionales / recomendado para BYOD	declaración de cumplimiento para	servicios críticos.
Firewall local habilitado	Obligatorio	Revisión de configuración del dispositivo o política de cumplimiento.	Denegar acceso administrativo.
Cliente ZTNA registrado	Obligatorio	Registro activo en Headscale.	Denegar conexión.
MFA habilitado	Obligatorio	Validación en Keycloak.	Denegar acceso.
Cifrado de disco	Obligatorio para equipos institucionales / recomendado para BYOD	Verificación de política de seguridad o declaración de cumplimiento.	Restringir acceso a datos sensibles.
Sin indicadores de compromiso	Obligatorio para equipos administrados	Alertas Wazuh/EDR o revisión de eventos recientes.	Aislar equipo y crear incidente.
Rol del usuario autorizado	Obligatorio	Validación de grupo o rol en Keycloak.	Denegar acceso al recurso solicitado.

Tabla 8. Controles de seguridad para dispositivos.

Para los equipos institucionales, la postura podrá validarse con mayor profundidad mediante agentes de seguridad y políticas administradas. Para dispositivos BYOD, por razones de privacidad, la validación se limitará a controles no invasivos, como registro del dispositivo, MFA, cliente ZTNA activo, sistema operativo soportado y aceptación de políticas de uso.

En ambos casos, el acceso a recursos sensibles se concederá únicamente cuando el usuario, el dispositivo y el contexto cumplan las condiciones definidas por la política Zero Trust.

2.10 Beneficios de la arquitectura propuesta

La adopción de una arquitectura basada en Zero Trust proporciona mejoras sustanciales frente al modelo actual:

Estado actual	Estado propuesto	Beneficio esperado
Red plana sin segmentación	Microsegmentación mediante VLANs	Reduce movimiento lateral y limita el alcance de un compromiso.
Firewall tradicional Stateful	pfSense + Suricata + reglas inter-VLAN	Mejora visibilidad, control de tráfico e identificación de amenazas.
Sin WAF para el Portal Académico	ModSecurity + OWASP CRS	Protege aplicaciones web contra ataques comunes como SQL Injection y XSS.

VPN PPTP/L2TP basada en usuario y contraseña	ZTNA con MFA y dispositivo registrado	Evita acceso amplio a la red y reduce impacto de credenciales robadas.
Confianza implícita en usuarios internos	Verificación continua de identidad, dispositivo y contexto	Aplica principios Zero Trust.
Dispositivos BYOD sin control	Acceso condicionado mediante ZTNA	Permite acceso seguro sin invadir privacidad del usuario.
Comunicación directa entre servidores	Matriz de reglas permitidas entre VLANs	Limita acceso únicamente a servicios requeridos.
Sin monitoreo centralizado	Integración con Wazuh SIEM/EDR	Mejora detección temprana, auditoría y respuesta ante incidentes.
Backups expuestos al mismo entorno	VLAN dedicada para backups	Reduce riesgo de cifrado o eliminación durante ransomware.
Administración técnica amplia	VLAN de Gestión con MFA	Protege accesos privilegiados y reduce abuso de cuentas administrativas.

Tabla 9. Beneficios de arquitectura propuesta sobre la actual.

La arquitectura propuesta transforma el modelo de seguridad de CREATIC desde un enfoque perimetral tradicional hacia una arquitectura moderna basada en Zero Trust, Defensa en Profundidad y principios SASE. La sustitución de la red plana por microsegmentación, la incorporación de pfSense con Suricata, el uso de ModSecurity como WAF, la adopción de ZTNA con Headscale/Tailscale y la integración con Keycloak y Wazuh permiten reducir los principales riesgos identificados en el diagnóstico inicial.

El cambio más importante consiste en eliminar la confianza implícita. Bajo el nuevo modelo, los usuarios, dispositivos y aplicaciones deberán ser verificados antes de acceder a los recursos institucionales. Además, la comunicación entre segmentos quedará limitada a flujos estrictamente necesarios, reduciendo el riesgo de movimiento lateral y protegiendo activos críticos como CR-DC-01, CR-DB-01, CR-FILE-03 y CR-APPSRV-02.

Esta arquitectura crea la base técnica para los módulos posteriores, especialmente las operaciones de seguridad con Wazuh, el hardening automatizado, el cumplimiento de la Ley 81 y el plan de respuesta a incidentes.

2.11 Viabilidad económica y presupuesto estimado

La arquitectura propuesta para CREATIC fue diseñada considerando una restricción clave del proyecto: **no adquirir licencias comerciales de seguridad**. Por esta razón, se seleccionaron herramientas Open Source que permiten cubrir funciones de firewall, IDS/IPS, WAF, gestión de identidad, ZTNA, SIEM/EDR, automatización y monitoreo sin incurrir en costos de licenciamiento propietario.

Las principales herramientas seleccionadas son Wazuh, pfSense Community Edition, Suricata, Keycloak, ModSecurity con OWASP Core Rule Set y Headscale/Tailscale. Wazuh se presenta como una plataforma gratuita y Open Source para SIEM/XDR; pfSense Community Edition es una solución gratuita y Open Source de firewall/router; Suricata es una herramienta Open Source de análisis de red y detección de amenazas; Keycloak es una solución Open Source de identidad y control de acceso; y ModSecurity con OWASP CRS permite implementar protección WAF mediante reglas abiertas para aplicaciones web.

Aunque el costo de licenciamiento comercial es **USD \$0**, la implementación real sí requiere inversión en infraestructura, almacenamiento, configuración técnica, pruebas, documentación, capacitación y operación. Por tanto, el presupuesto debe entenderse como una estimación de implementación y operación, no como compra de licencias.

Componente	Descripción	Costo estimado
Licencias comerciales	Uso de herramientas Open Source para SIEM/EDR, firewall, IDS/IPS, WAF, IAM y ZTNA.	USD \$0
Servidor o VM para Wazuh	Recursos para Wazuh Manager, Indexer y Dashboard.	USD \$3,000 – \$8,000
Firewall pfSense / Suricata	Equipo físico o VM dedicada para control perimetral, inter-VLAN e IDS/IPS.	USD \$1,500 – \$5,000
Almacenamiento de logs y backups	Espacio para retención de logs, evidencias e información de respaldo.	USD \$3,000 – \$10,000
Implementación Zero Trust / ZTNA / MFA	Configuración de segmentación, Keycloak, Headscale/Tailscale y políticas de acceso.	USD \$5,000 – \$12,000
Implementación SOC Open Source	Configuración de Wazuh, fuentes de ingesta, reglas de correlación, Shuffle y TheHive.	USD \$6,000 – \$15,000
Pipeline DevSecOps	Integración de SAST, SCA, DAST, análisis de secretos y escaneo de contenedores.	USD \$3,000 – \$8,000
Hardening automatizado	Desarrollo y validación de playbooks Ansible y scripts PowerShell.	USD \$4,000 – \$10,000
Documentación, cumplimiento e IRP	Matriz de riesgos, Ley 81, política de retención de logs y plan de respuesta a incidentes.	USD \$3,000 – \$7,000
Capacitación y transferencia	Entrenamiento básico para TI, SOC y CSIRT interno.	USD \$2,000 – \$5,000

Tabla 10. Costes de los componentes.

Inversión inicial estimada: USD \$25,000 – \$65,000.

Este rango puede disminuir si CREATIC reutiliza infraestructura existente, servidores virtuales disponibles o almacenamiento ya contratado. También puede aumentar si se requiere adquisición de hardware dedicado, alta

disponibilidad, soporte externo permanente o mayor capacidad de almacenamiento para logs.

Costos operativos anuales estimados

Concepto recurrente	Descripción	Costo anual estimado
Mantenimiento de infraestructura	Actualizaciones, recursos de cómputo, almacenamiento y respaldo.	USD \$2,000 – \$6,000
Operación y ajuste del SOC	Tuning de reglas, revisión de alertas, correlación y mejora continua.	USD \$6,000 – \$18,000
Simulacros y capacitación	Ejercicios de respuesta a incidentes, phishing y entrenamiento CSIRT.	USD \$2,000 – \$6,000
Soporte técnico o consultoría puntual	Apoyo especializado para incidentes, mejoras o auditorías.	USD \$5,000 – \$15,000

Tabla 11. Costes operativos.

Costo operativo anual estimado: USD \$15,000 – \$45,000.

En comparación con una arquitectura basada en licencias comerciales de SIEM, EDR, NGFW, ZTNA y SOAR, la propuesta reduce significativamente el costo de entrada al aprovechar soluciones Open Source. La inversión se concentra en implementación, operación y madurez del equipo interno, no en licenciamiento propietario. Esto hace que la solución sea económicamente viable para CREATIC, manteniendo alineación con Zero Trust, Defensa en Profundidad y cumplimiento regulatorio.

MÓDULO 3. Operaciones de Seguridad y Protección de Endpoints bajo Restricción Presupuestaria

3.1 Introducción

La arquitectura Zero Trust propuesta en el módulo anterior fortalece significativamente los mecanismos de autenticación, autorización y segmentación de la infraestructura tecnológica de CREATIC. Sin embargo, ningún control preventivo garantiza por sí solo la eliminación del riesgo. Los ataques modernos pueden aprovechar vulnerabilidades desconocidas, credenciales comprometidas o errores humanos para obtener acceso inicial a los sistemas.

Por esta razón, toda arquitectura Zero Trust debe complementarse con capacidades de monitoreo continuo, correlación de eventos, detección temprana y respuesta automatizada frente a incidentes de seguridad.

Actualmente, CREATIC presenta importantes limitaciones en materia de visibilidad operativa. Los servidores generan registros de eventos de forma independiente, los equipos administrativos dependen de un antivirus tradicional

basado en firmas y los dispositivos personales utilizados por docentes bajo el modelo BYOD no poseen ningún mecanismo de supervisión institucional. Esta situación impide detectar oportunamente ataques coordinados o actividades maliciosas distribuidas en diferentes componentes de la infraestructura.

Dado que el proyecto establece una restricción presupuestaria de **USD \$0** para licencias comerciales, se propone la implementación de un **Centro de Operaciones de Seguridad (SOC)** completamente basado en soluciones Open Source, utilizando **Wazuh** como plataforma SIEM/EDR, **Shuffle** para la automatización de respuestas (SOAR) y **TheHive** para la gestión de incidentes por parte del equipo CSIRT.

Esta arquitectura permitirá centralizar el monitoreo de todos los activos críticos, reducir los tiempos de detección y respuesta, automatizar acciones de contención inicial y proporcionar trazabilidad completa sobre los eventos de seguridad ocurridos dentro de la organización.

3.2 Objetivos del SOC

El Centro de Operaciones de Seguridad propuesto tendrá los siguientes objetivos:

- Centralizar la recolección de eventos provenientes de toda la infraestructura tecnológica.
- Detectar comportamientos anómalos mediante reglas de correlación.
- Automatizar respuestas iniciales frente a incidentes críticos.
- Facilitar las investigaciones del CSIRT mediante una plataforma de gestión de casos.
- Mejorar los indicadores MTTD y MTTR definidos en el Módulo 7.
- Cumplir con los principios de monitoreo continuo establecidos por la arquitectura Zero Trust.

3.3 Justificación tecnológica

La solución propuesta fue diseñada considerando tres criterios fundamentales:

- Restricción presupuestaria.
- Escalabilidad.
- Integración con la arquitectura definida anteriormente.

Herramienta	Función	Justificación
Wazuh	SIEM + EDR	Plataforma Open Source con monitoreo, correlación, FIM, gestión de vulnerabilidades y Active Response.

Wazuh Agent	Recolección de eventos	Instalado en todos los servidores corporativos.
Wazuh Manager	Correlación	Analiza eventos y genera alertas.
Wazuh Indexer	Almacenamiento	Indexa los eventos para búsquedas rápidas.
Wazuh Dashboard	Visualización	Consola de monitoreo del SOC.
Shuffle	SOAR	Automatiza playbooks de respuesta sin costo.
TheHive	Gestión de Incidentes	Plataforma para el seguimiento de incidentes por parte del CSIRT.

Tabla 12. Herramientas propuestas

La incorporación de Shuffle y TheHive no representa un costo adicional para la institución y amplía considerablemente las capacidades operativas del SOC, permitiendo automatizar tareas repetitivas y documentar adecuadamente cada incidente de seguridad.

3.4 Arquitectura del SOC

La Figura 4 presenta la arquitectura lógica propuesta para el Centro de Operaciones de Seguridad de CREATIC. Esta arquitectura centraliza la recolección, correlación, visualización y respuesta ante eventos de seguridad utilizando herramientas Open Source.

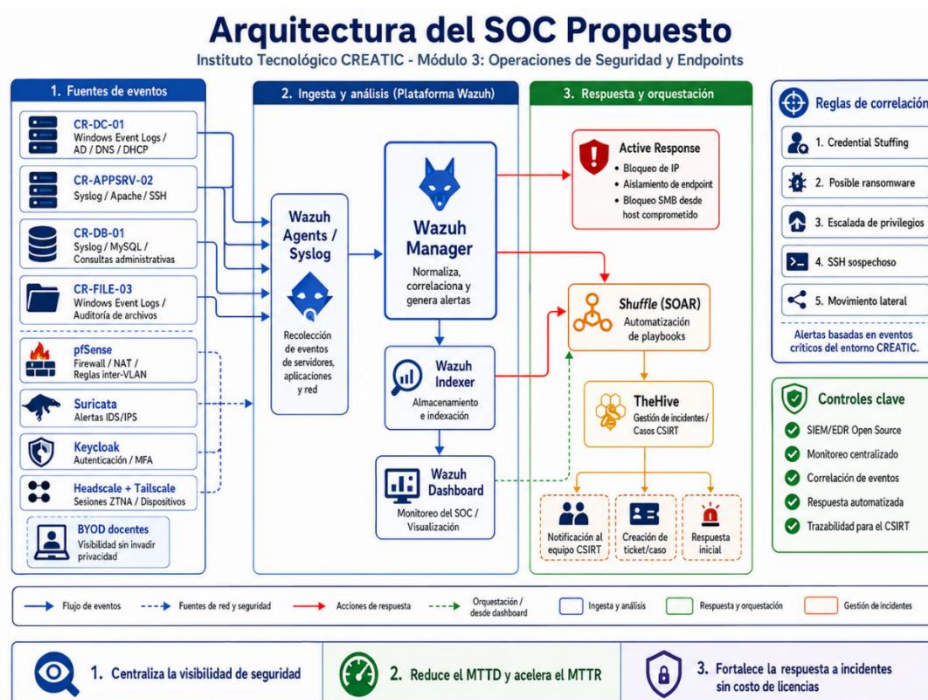


Figura 4. Arquitectura del SOC Propuesto

El flujo operacional será el siguiente:

1. Los servidores Windows y Linux generan eventos de seguridad.
2. Los agentes Wazuh recopilan dichos eventos.
3. El Wazuh Manager normaliza, analiza y correlaciona la información recibida.
4. Los eventos se almacenan en el Wazuh Indexer.
5. El Dashboard permite al analista visualizar alertas en tiempo real.
6. Cuando una alerta cumple determinados criterios, Wazuh ejecuta una respuesta automática mediante Active Response o envía el evento a Shuffle.
7. Shuffle ejecuta un playbook automatizado (por ejemplo, bloquear una IP o aislar un endpoint).
8. Paralelamente, se crea un caso en TheHive para que el CSIRT documente la investigación y realice las acciones correspondientes.

3.5 Fuentes de ingesta

Uno de los factores más importantes para la efectividad del SIEM es la diversidad de fuentes de información integradas. En la propuesta se consideran los siguientes orígenes de eventos:

Fuente	Registros recolectados	Finalidad de monitoreo
CR-DC-01	Windows Event Logs, Active Directory, DNS, DHCP, eventos 4625, 4720, 4728 y 4732	Detectar accesos fallidos, creación de usuarios, cambios en grupos privilegiados y anomalías de autenticación.
CR-APPSRV-02	Syslog, /var/log/auth.log, Apache Access Log, Apache Error Log, eventos SSH	Detectar intentos de acceso root, errores del portal, ataques web y actividad sospechosa en Apache.
CR-DB-01	Syslog, MySQL Error Log, autenticación, consultas administrativas	Detectar accesos indebidos, errores de base de datos y consultas administrativas anómalas.
CR-FILE-03	Windows Event Logs, eventos 4663, 5140 y 5145, auditoría de carpetas compartidas	Detectar accesos no autorizados, modificaciones masivas y posible ransomware.

pfSense	Firewall logs, NAT, reglas bloqueadas, conexiones entre VLANs	Detectar tráfico no autorizado, escaneos y movimiento lateral.
Suricata	Alertas IDS/IPS en formato EVE JSON	Identificar firmas de ataque, exploits, escaneos y tráfico malicioso.
Keycloak	Eventos de autenticación, MFA exitoso/fallido, cambios de sesión	Detectar abuso de credenciales y fallos repetidos de autenticación.
Headscale/Tailscale	Registro de dispositivos, sesiones ZTNA, conexiones autorizadas	Validar acceso remoto, dispositivos registrados y trazabilidad de sesiones.

Tabla 13. Logs y eventos registrados

La integración de estas fuentes proporciona visibilidad sobre la totalidad del ciclo de vida de un incidente, desde el acceso inicial hasta las acciones de respuesta.

3.6 Estrategia para dispositivos BYOD

Los aproximadamente 250 docentes contratistas utilizan dispositivos personales para acceder a los servicios institucionales. Debido a restricciones legales y de privacidad, no resulta apropiado instalar agentes EDR completos sobre equipos que no pertenecen a la institución.

En su lugar, se propone una estrategia basada en **Zero Trust**:

- Registro obligatorio del dispositivo en Headscale.
- Conexión mediante Tailscale.
- MFA obligatorio.
- Evaluación de postura antes del acceso.
- Acceso únicamente mediante ZTNA.
- Registro de autenticaciones.
- Registro de sesiones.
- Registro de cambios de dispositivo.

De esta forma, la organización obtiene visibilidad sobre el acceso a los recursos corporativos sin invadir la privacidad del usuario.

Esta estrategia permite obtener trazabilidad del acceso institucional sin inspeccionar archivos personales, historial local ni información privada del

dispositivo, manteniendo un equilibrio entre seguridad, privacidad y cumplimiento regulatorio.

3.7 Reglas de correlación

Las siguientes reglas fueron diseñadas específicamente para el escenario de CREATIC.

Regla 1 – Credential Stuffing

Regla 2 – Posible ransomware

Regla 3 – Escalada de privilegios

Regla 4 – SSH sospechoso

Regla 5 – Movimiento lateral

Esta última regla está directamente alineada con la arquitectura Zero Trust diseñada en el Módulo 2.

Las siguientes reglas de correlación fueron diseñadas para el escenario de CREATIC y se enfocan en los principales riesgos identificados: abuso de credenciales, ransomware, escalada de privilegios, accesos SSH sospechosos y movimiento lateral entre segmentos.

#	Regla	Descripción	Condiciones de detección	Respuesta automática
1	Credential Stuffing	Detectar múltiples intentos fallidos de autenticación utilizando una misma dirección IP	• Más de cinco intentos fallidos. • Intervalo menor a cinco minutos. • Mismo usuario o misma dirección IP.	• Alerta Alta. • Bloqueo temporal de la dirección IP mediante pfSense. • Creación automática del incidente en TheHive.
2	Posible ransomware	Detectar modificaciones masivas de archivos compartidos	• Más de cien modificaciones de archivos. • Intervalo inferior a un minuto.	• Active Response. • Aislamiento del endpoint. • Bloqueo de SMB. • Creación automática del incidente en TheHive.
3	Escalada de privilegios	Detectar la creación o	• Creación de un usuario privilegiado.	• Alerta Crítica.

		asignación de nuevos administradores.	• Modificación de grupo Domain Admin	• Notificación inmediata al equipo de seguridad. • Registro del incidente en TheHive.
4	SSH sospechoso	Intentos repetidos de acceso SSH al servidor Apache.	• Intentos de autenticación con el usuario root. • Más de tres intentos fallidos. • Conexión proveniente de una dirección IP externa	• Bloqueo automático de IP. • Registro del evento en Wazuh. • Creación automática de un ticket.
5	Movimiento lateral	Detectar comunicaciones no autorizadas entre VLANs.	• Tráfico desde la VLAN BYOD hacia la VLAN Servidores. • Uso de puertos distintos a los autorizados	• Bloqueo inmediato en pfSense. • Alerta Crítica. • Caso automático de incidente en TheHive.

Tabla 14. Reglas de correlación.

3.8 Automatización mediante SOAR

Uno de los principales beneficios de incorporar Shuffle consiste en automatizar tareas repetitivas del SOC.

Por ejemplo, ante la detección de un posible Credential Stuffing:

1. Wazuh genera una alerta.
2. Shuffle recibe el evento.
3. Consulta la reputación de la IP (VirusTotal o AbuseIPDB, si se desea ampliar en el futuro).
4. Si la IP es maliciosa, actualiza automáticamente las reglas de pfSense.
5. Crea un incidente en TheHive.
6. Envía una notificación por correo electrónico al equipo CSIRT.

Esta automatización reduce significativamente el tiempo de respuesta y minimiza la intervención manual en incidentes recurrentes.

3.9 Dashboards

El Dashboard del SOC permitirá visualizar indicadores como:

- Eventos por hora.
- Incidentes por criticidad.
- Equipos con mayor cantidad de alertas.
- Intentos de autenticación fallidos.
- Estado de los agentes Wazuh.
- Alertas generadas por Suricata.
- Vulnerabilidades detectadas.
- Actividad de dispositivos BYOD.
- Eventos MFA.
- Tendencia semanal de incidentes.

Estos paneles facilitarán el monitoreo continuo y la toma de decisiones por parte del equipo de seguridad.

3.10 Beneficios

La arquitectura propuesta proporciona beneficios técnicos y operativos significativos:

- Visibilidad centralizada sobre toda la infraestructura.
- Correlación de eventos provenientes de múltiples fuentes.
- Detección temprana de amenazas.
- Respuesta automatizada mediante SOAR.
- Gestión formal de incidentes mediante TheHive.
- Integración completa con la arquitectura Zero Trust.
- Reducción del MTTD y MTTR.
- Eliminación de costos por licenciamiento.

MÓDULO 4. Integración de DevSecOps en el Ciclo de Desarrollo Seguro

4.1 Introducción

La transformación digital ha incrementado la dependencia de las organizaciones respecto a las aplicaciones web como medio para ofrecer servicios a estudiantes, docentes y personal administrativo. En el caso del Instituto Tecnológico CREATIC, el Portal Académico constituye uno de los activos más críticos de la organización, ya que centraliza procesos relacionados con autenticación de usuarios, consulta de información académica, gestión administrativa y acceso a recursos institucionales.

Tradicionalmente, la seguridad de las aplicaciones ha sido abordada al final del proceso de desarrollo, mediante pruebas manuales o auditorías realizadas poco antes de la puesta en producción. Este enfoque genera altos costos de corrección, retrasa las entregas y aumenta la probabilidad de que vulnerabilidades críticas alcancen el entorno productivo.

Como respuesta a esta problemática, surge el enfoque **DevSecOps**, una evolución de DevOps que integra controles de seguridad automatizados durante todo el ciclo de vida del desarrollo de software (Secure Software Development Life Cycle - SSDLC). Bajo este paradigma, la seguridad deja de ser una actividad aislada y pasa a formar parte de cada etapa del proceso, desde la escritura del código hasta el despliegue y monitoreo de la aplicación.

En este módulo se propone un pipeline DevSecOps para CREATIC, empleando exclusivamente herramientas Open Source y alineado con la arquitectura Zero Trust y el Centro de Operaciones de Seguridad definidos en los módulos anteriores.

4.2 Diagnóstico del proceso actual

El proceso de desarrollo actual presenta un flujo tradicional donde el código desarrollado es desplegado sin un conjunto de validaciones automáticas de seguridad.

El flujo actual puede representarse de la siguiente forma:

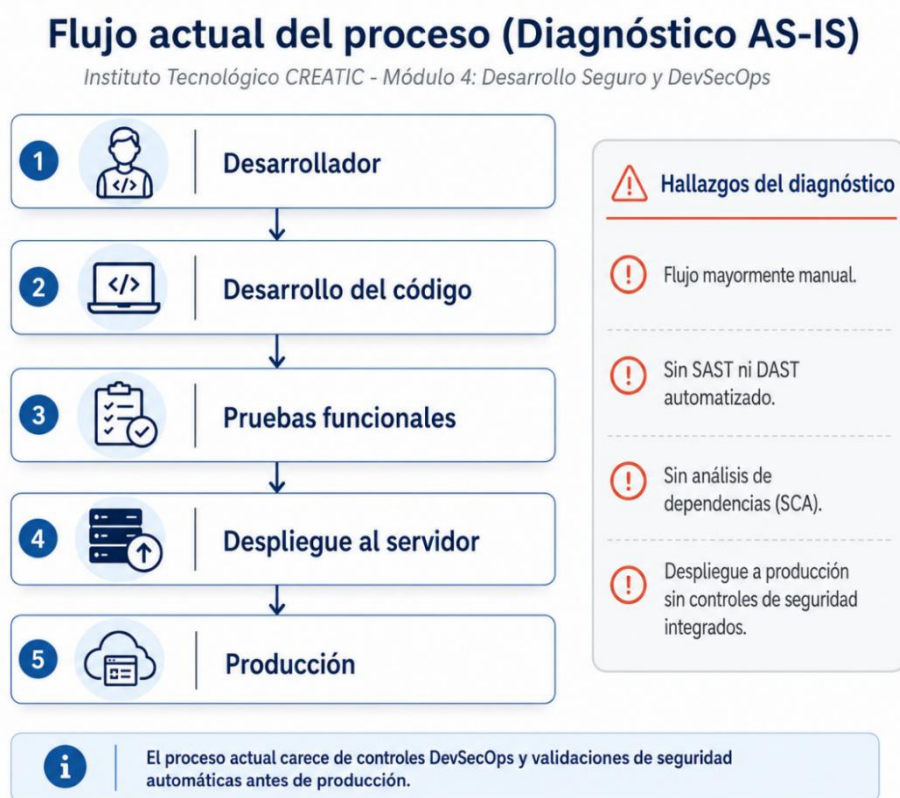


Figura 5. Flujo actual (AS-IS)

Este modelo presenta diversas limitaciones:

- No existe análisis estático del código fuente antes de su integración.
- No se verifica la seguridad de las librerías de terceros utilizadas por la aplicación.
- No se detecta la inclusión accidental de credenciales, claves API o secretos dentro del repositorio.
- No se realizan pruebas automáticas de seguridad sobre la aplicación desplegada.
- El despliegue depende principalmente de verificaciones manuales, aumentando el riesgo de error humano.

Estas debilidades incrementan la probabilidad de introducir vulnerabilidades como inyección SQL, Cross-Site Scripting (XSS), exposición de información sensible o uso de dependencias con vulnerabilidades conocidas.

4.3 Arquitectura DevSecOps propuesta

Con el objetivo de incorporar controles de seguridad desde las primeras fases del desarrollo, se propone un pipeline automatizado basado en herramientas Open Source.

La arquitectura propuesta está compuesta por las siguientes etapas:

Etapas	Herramienta propuesta	Objetivo
Control de versiones	GitHub	Gestión centralizada del código fuente.
Integración continua	GitHub Actions	Automatización del pipeline.
Análisis estático (SAST)	Semgrep	Identificación de vulnerabilidades en el código fuente.
Análisis de dependencias (SCA)	OWASP Dependency-Check	Detección de librerías vulnerables.
Detección de secretos	Gitleaks	Identificación de contraseñas, tokens y claves expuestas.
Construcción	Docker	Generación de artefactos reproducibles.
Escaneo de contenedores	Trivy	Identificación de vulnerabilidades en imágenes Docker.
Análisis dinámico (DAST)	OWASP ZAP	Evaluación de la aplicación en ejecución.

Despliegue	Apache Server	Publicación de la aplicación.
Monitoreo	Wazuh	Supervisión continua y correlación de eventos.

Tabla 15. Arquitectura DevSecOps.

Esta arquitectura garantiza que toda modificación al código sea sometida automáticamente a controles de seguridad antes de ser desplegada en producción.

4.4 Flujo del Pipeline DevSecOps

El pipeline propuesto sigue una secuencia de validaciones automáticas que permiten detectar vulnerabilidades en diferentes niveles del proceso de desarrollo.

1. El desarrollador realiza cambios en el código fuente y los envía al repositorio GitHub.
2. GitHub Actions detecta el nuevo commit e inicia automáticamente el pipeline.
3. Sengrep ejecuta un análisis estático para identificar vulnerabilidades comunes como SQL Injection, XSS, Command Injection o Path Traversal.
4. OWASP Dependency-Check analiza las dependencias del proyecto y verifica la existencia de vulnerabilidades conocidas (CVE).
5. Gitleaks inspecciona el repositorio para detectar la presencia de contraseñas, tokens, claves privadas o credenciales expuestas.
6. Si las etapas anteriores son satisfactorias, se construye la imagen Docker de la aplicación.
7. Trivy analiza la imagen generada para identificar paquetes vulnerables o configuraciones inseguras.
8. La aplicación se despliega en un entorno temporal donde OWASP ZAP ejecuta pruebas dinámicas de seguridad.
9. Si todas las validaciones son superadas, la aplicación es desplegada al servidor Apache.
10. Finalmente, los registros del pipeline y del servidor son enviados a Wazuh para su monitoreo y auditoría.

Este flujo garantiza que únicamente aplicaciones que cumplan los estándares mínimos de seguridad puedan ser promovidas al entorno productivo.

4.5 Controles de seguridad implementados

4.5.1 Análisis Estático (SAST)

El análisis estático se realizará mediante **Semgrep**, herramienta que inspecciona el código fuente sin necesidad de ejecutar la aplicación.

Entre las vulnerabilidades detectadas se incluyen:

- Inyección SQL.
- Cross-Site Scripting (XSS).
- Uso inseguro de funciones del sistema.
- Hardcoded Credentials.
- Path Traversal.
- Command Injection.

La ejecución de este análisis en cada commit permite detectar vulnerabilidades durante la fase de desarrollo, reduciendo significativamente el costo de corrección.

4.5.2 Análisis de Dependencias (SCA)

Las aplicaciones modernas incorporan múltiples bibliotecas de terceros que pueden contener vulnerabilidades conocidas.

Para reducir este riesgo se propone utilizar **OWASP Dependency-Check**, herramienta que compara las dependencias del proyecto con bases de datos públicas de vulnerabilidades (CVE).

Si se detecta una dependencia crítica, el pipeline será detenido hasta que el desarrollador actualice la versión afectada.

4.5.3 Detección de Secretos

La exposición accidental de credenciales dentro del código constituye una de las causas más frecuentes de compromiso de aplicaciones.

Se implementará **Gitleaks** para detectar automáticamente:

- Contraseñas.
- API Keys.
- Tokens JWT.
- Claves SSH.
- Certificados privados.
- Secretos de bases de datos.

La detección de cualquiera de estos elementos provocará la interrupción inmediata del pipeline.

4.5.4 Escaneo de Contenedores

La aplicación será distribuida mediante contenedores Docker.

Antes de su despliegue, **Trivy** analizará la imagen para identificar:

- Paquetes vulnerables.
- Dependencias obsoletas.
- Configuraciones inseguras.
- CVEs de alta criticidad.

Solo las imágenes que cumplan las políticas de seguridad podrán avanzar a la siguiente etapa.

4.5.5 Pruebas Dinámicas (DAST)

Una vez desplegada la aplicación en un entorno de pruebas, **OWASP ZAP** ejecutará análisis dinámicos para detectar vulnerabilidades que únicamente pueden identificarse durante la ejecución del sistema.

Entre ellas:

- SQL Injection.
- Cross-Site Scripting.
- Directory Traversal.
- Broken Authentication.
- Session Management.
- Exposición de información sensible.

Los resultados serán incluidos automáticamente dentro del reporte del pipeline.

4.6 Integración con la Arquitectura Zero Trust

El pipeline DevSecOps complementa la arquitectura Zero Trust propuesta en el Módulo 2 al garantizar que únicamente aplicaciones verificadas puedan ser desplegadas en la infraestructura institucional.

La integración entre ambos enfoques proporciona una defensa multicapa donde:

- Zero Trust protege el acceso a los recursos.
- DevSecOps protege el software desplegado.

- El SOC supervisa continuamente el comportamiento de la aplicación una vez en producción.

Esta estrategia reduce la probabilidad de explotación de vulnerabilidades introducidas durante el desarrollo.

En caso de que un atacante lograra explotar la vulnerabilidad RCE de la librería PDF y comprometiera el servidor CR-APPSRV-02, la arquitectura Zero Trust propuesta reduciría el impacto del incidente. El servidor web ubicado en la DMZ no tendría comunicación libre con toda la red interna; únicamente podría conectarse a CR-DB-01 por el puerto estrictamente requerido por la aplicación, bajo reglas controladas en pfSense.

Además, la cuenta de servicio utilizada por el portal tendría privilegios mínimos sobre la base de datos, evitando acceso administrativo o consultas fuera de su función. Cualquier intento de conexión hacia CR-DC-01, CR-FILE-03, VLAN de gestión o segmentos no autorizados sería bloqueado y registrado en Wazuh para análisis del SOC.

4.7 Integración con el SOC

Todos los eventos generados durante el pipeline serán registrados y enviados a Wazuh.

Entre los eventos monitoreados se incluyen:

- Fallos en análisis SAST.
- Vulnerabilidades detectadas por Dependency-Check.
- Hallazgos de Gitleaks.
- Resultados de Trivy.
- Alertas generadas por OWASP ZAP.
- Despliegues exitosos.
- Despliegues rechazados.

La correlación de estos eventos permitirá al SOC mantener trazabilidad sobre cada versión desplegada y detectar patrones de riesgo asociados al proceso de desarrollo.

4.8 Criterios de aprobación del pipeline

Para garantizar un nivel mínimo de seguridad, se establecen las siguientes políticas de aceptación:

Control	Criterio de aceptación recomendado	Acción
Semgrep / SAST	Sin vulnerabilidades críticas o de alto impacto en código propio	Detener pipeline

Dependency-Check / SCA	Sin dependencias con CVSS ≥ 7.0 en componentes expuestos, sin RCE conocida y sin CVE crítico activo	Detener pipeline
Gitleaks	Sin contraseñas, tokens, claves privadas o secretos detectados	Detener pipeline
Trivy	Sin vulnerabilidades críticas en imagen Docker base o paquetes del contenedor	Bloquear construcción
OWASP ZAP / DAST	Sin vulnerabilidades críticas explotables en entorno de pruebas	No desplegar a producción
Revisión de despliegue	Aprobación manual para producción después de pasar controles automáticos	Liberar versión controlada

Tabla 16. Criterios de aprobación.

Estas políticas garantizan que únicamente aplicaciones que cumplan los estándares definidos por la organización puedan ser liberadas al entorno productivo.

4.9 Beneficios de la propuesta

La incorporación de DevSecOps aporta beneficios técnicos y organizacionales para CREATIC:

- Integración de la seguridad desde las primeras fases del desarrollo.
- Reducción de vulnerabilidades antes del despliegue.
- Automatización de controles de seguridad.
- Disminución del riesgo asociado a errores humanos.
- Mayor trazabilidad sobre cada versión del software.
- Integración con el SOC para monitoreo continuo.
- Uso exclusivo de herramientas Open Source, eliminando costos de licenciamiento.

MÓDULO 5: Automatización de Hardening

5.1 Introducción

La arquitectura Zero Trust propuesta para CREATIC requiere que los servidores críticos operen bajo configuraciones seguras, verificables y repetibles. No basta con definir controles de seguridad a nivel conceptual; es necesario automatizar su aplicación para reducir errores humanos, mantener consistencia entre sistemas y acelerar la remediación de configuraciones inseguras.

En el estado actual de la infraestructura, los activos principales presentan debilidades críticas: el servidor web CR-APPSRV-02 permite acceso SSH por el puerto 22, el servidor CR-DB-01 se encuentra en el mismo entorno lógico que el servidor web, el controlador CR-DC-01 mantiene configuraciones por defecto y el servidor CR-FILE-03 presenta permisos laxos sobre recursos compartidos. Estas condiciones incrementan el riesgo de movimiento lateral, explotación de servicios inseguros, robo de credenciales y ransomware.

Por esta razón, este módulo implementa una estrategia de hardening automatizado mediante código de infraestructura. Para los servidores Linux se utiliza Ansible, mientras que para los servidores Windows se emplean scripts de PowerShell. Esta decisión permite aplicar controles técnicos de forma estructurada, documentada y verificable, alineándose con los principios de mínimo privilegio, defensa en profundidad y automatización segura.

5.2 Objetivo del módulo

El objetivo de este módulo es automatizar la aplicación de controles de hardening sobre los cuatro servidores críticos definidos en el inventario tecnológico de CREATIC:

Servidor	Sistema operativo	Rol	Herramienta de automatización
CR-APPSRV-02	Debian 11	Servidor web Apache / Portal Académico	Ansible
CR-DB-01	Debian 11	Servidor de base de datos MariaDB	Ansible
CR-DC-01	Windows Server	Servidor de identidad / controlador de dominio lógico	PowerShell
CR-FILE-03	Windows Server	Servidor de archivos administrativos	PowerShell

Tabla 17. Servidores críticos de CREATIC.

La automatización busca corregir configuraciones inseguras, reducir la superficie de ataque y dejar evidencia técnica del estado pre-hardening y post-hardening de cada servidor.

5.3 Alcance de la automatización

El hardening implementado cubre controles específicos para sistemas Linux y Windows, priorizando las vulnerabilidades descritas en el caso de estudio y en los módulos anteriores.

Para Linux, el playbook de Ansible aplica controles sobre los servidores CR-APPSRV-02 y CR-DB-01. Las acciones principales incluyen endurecimiento de SSH, cambio del puerto por defecto, deshabilitación del login directo de root, eliminación de servicios y paquetes innecesarios, configuración del firewall UFW y validación de servicios críticos.

Para Windows, los scripts de PowerShell aplican controles sobre CR-DC-01 y CR-FILE-03. Las acciones principales incluyen deshabilitación de SMBv1, aplicación de políticas restrictivas de contraseñas, bloqueo por intentos fallidos, deshabilitación de la cuenta Guest, activación del firewall y ajuste de permisos sobre recursos compartidos.

Este módulo no sustituye las capacidades de monitoreo del SOC, sino que las complementa. Los cambios aplicados reducen la probabilidad de explotación, mientras que Wazuh, definido en el Módulo 3, mantiene la capacidad de detección, correlación y respuesta ante eventos de seguridad.

5.4 Arquitectura de archivos del repositorio

Los archivos de automatización fueron organizados en un repositorio de código para facilitar su revisión, reutilización y mantenimiento. La estructura propuesta es la siguiente:

```
creatic-zero-trust-security/  
|  
|— README.md  
|  
|— ansible/  
|   |— ansible.cfg  
|   |— inventory.ini  
|   |— hardening_linux.yml  
|   |— group_vars/  
|       |— all.yml  
|— powershell/  
|   |— hardening_windows_file.ps1  
|   |— hardening_windows_dc.ps1  
|  
|— evidence/  
    |— EvidenciasVMS.docx
```

Esta estructura permite separar claramente los archivos de configuración, los scripts de automatización y las evidencias de ejecución. Además, facilita que un auditor o evaluador pueda revisar el código utilizado sin depender de las máquinas virtuales completas.

5.5 Hardening automatizado en Linux con Ansible

Para los servidores Linux se implementó un playbook de Ansible llamado `hardening_linux.yml`. Este archivo se ejecuta desde el nodo controlador y aplica controles de seguridad sobre CR-APPSRV-02 y CR-DB-01.

La automatización utiliza archivos complementarios para mantener una configuración ordenada:

Archivo	Función
ansible.cfg	Define el inventario, desactiva la verificación estricta de claves SSH y ajusta parámetros generales de Ansible.
inventory.ini	Contiene los servidores Linux administrados y su clasificación por rol.
group_vars/all.yml	Centraliza variables como puerto SSH, red de administración, IP del servidor web y puertos permitidos.
hardening_linux.yml	Playbook principal de hardening.

Tabla 18. Archivos complementarios para hardening de Linux.

Controles aplicados en Linux

Control	Implementación técnica	Servidor impactado	Resultado esperado
Cambio de puerto SSH	Configuración de SSH en el puerto 2222	CR-APPSRV-02 / CR-DB-01	Reducir exposición del puerto 22
Deshabilitar root por SSH	PermitRootLogin no	CR-APPSRV-02 / CR-DB-01	Evitar acceso administrativo directo
Bloquear contraseñas vacías	PermitEmptyPasswords no	CR-APPSRV-02 / CR-DB-01	Impedir autenticación insegura

Limitar intentos SSH	MaxAuthTries 3	CR-APPSRV-02 / CR-DB-01	Reducir fuerza bruta
Deshabilitar X11 Forwarding	X11Forwarding no	CR-APPSRV-02 / CR-DB-01	Reducir superficie de ataque
Instalar Fail2ban	Configuración de jail para SSH	CR-APPSRV-02 / CR-DB-01	Bloquear intentos repetidos
Configurar UFW	Denegar entrada por defecto y permitir solo tráfico necesario	CR-APPSRV-02 / CR-DB-01	Aplicar mínimo privilegio de red
Permitir HTTP/HTTPS	Reglas UFW para 80 y 443	CR-APPSRV-02	Mantener servicio web funcional
Restringir MariaDB	Permitir 3306 solo desde CR-APPSRV-02	CR-DB-01	Evitar acceso directo a la base de datos
Eliminar paquetes inseguros	Remoción de telnet, rsh, xinetd, tftp	CR-APPSRV-02 / CR-DB-01	Reducir servicios obsoletos
Actualizaciones automáticas	Configuración de unattended-upgrades	CR-APPSRV-02 / CR-DB-01	Mejorar remediación continua

Tabla 19. Controles aplicados en Linux.

Ejecución del playbook

El playbook se ejecuta desde el directorio linux/ mediante el siguiente comando:

```
ansible-playbook hardening_linux.yml --ask-pass --ask-become-pass
```

Durante la ejecución, Ansible aplica los controles definidos, reinicia los servicios necesarios y realiza verificaciones post-hardening para confirmar el estado deseado.

5.6 Verificación post-hardening en Linux

El playbook incorpora tareas de verificación para validar que los controles fueron aplicados correctamente. Entre las comprobaciones realizadas se encuentran:

Verificación	Comando o validación	Resultado esperado
Configuración SSH	sshd -T	Puerto 2222, root deshabilitado, contraseñas vacías bloqueadas
Estado del firewall	ufw status numbered	UFW activo con reglas por rol
Puerto SSH	ss -tulnp grep :2222	SSH escuchando en puerto 2222
Servicio Apache	systemctl is-active apache2	Apache activo en CR-APPSRV-02
Servicio MariaDB	systemctl is-active mariadb	MariaDB activo en CR-DB-01

Tabla 20. Tareas de verificación de controles.

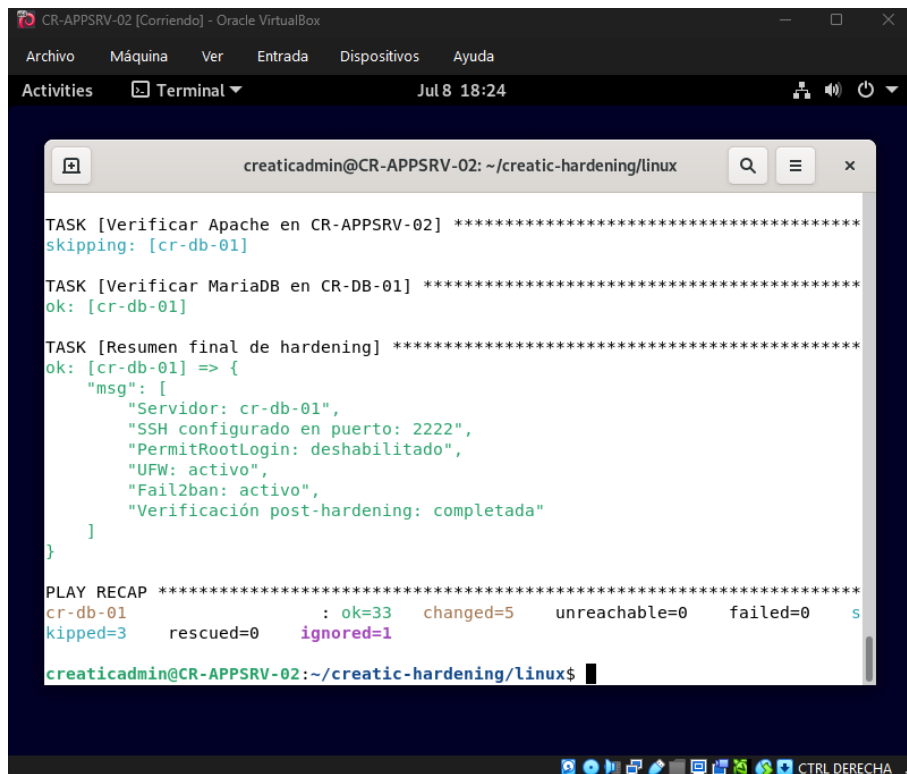
La evidencia recopilada demuestra que los servidores Linux pasaron de una configuración base vulnerable a una configuración endurecida, con controles de acceso remoto, firewall local y validación de servicios críticos.

```

cr-db-01 | CHANGED | rc=0 >>
CR-DB-01
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ hostname
CR-APPSRV-02
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ sudo grep -E "Port|PermitRootLogin|PermitEmptyPasswords|X11Forwarding" /etc/ssh/sshd_config
#Port 22
#PermitRootLogin prohibit-password
#PermitEmptyPasswords no
# the setting of "PermitRootLogin without-password".
#GatewayPorts no
X11Forwarding yes
#    X11Forwarding no
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ sudo ufw status verbose
Status: inactive
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ sudo ss -tulnp | grep -E ':22|:80'
tcp LISTEN 0      128          0.0.0.0:22      0.0.0.0:*      users:((("sshd", pid=486, fd=3))
tcp LISTEN 0      511          *:80            *:80           users:((("apache2", pid=507, fd=4), ("apache2", pid=506, fd=4), ("apache2", pid=505, fd=4))
tcp LISTEN 0      128          [::]:22        [::]:*         users:((("sshd", pid=486, fd=4))
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$

```

Figura 6. CR-APPSRV-02 Pre-Hardening



```
creaticadmin@CR-APPSRV-02: ~/creatic-hardening/linux

TASK [Verificar Apache en CR-APPSRV-02] *****
skipping: [cr-db-01]

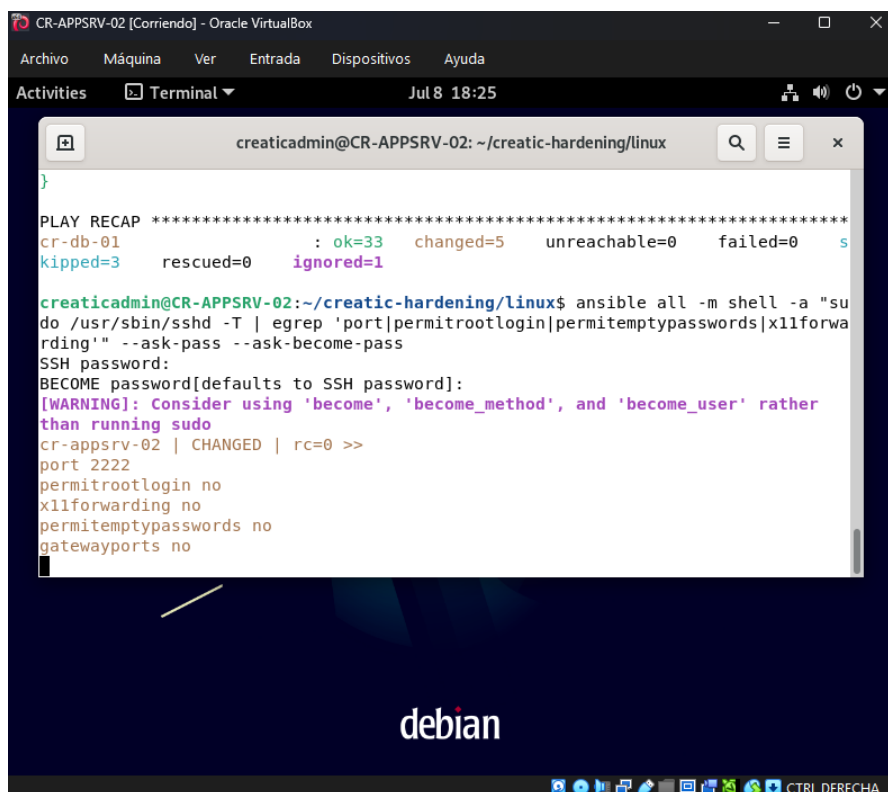
TASK [Verificar MariaDB en CR-DB-01] *****
ok: [cr-db-01]

TASK [Resumen final de hardening] *****
ok: [cr-db-01] => {
  "msg": [
    "Servidor: cr-db-01",
    "SSH configurado en puerto: 2222",
    "PermitRootLogin: deshabilitado",
    "UFW: activo",
    "Fail2ban: activo",
    "Verificación post-hardening: completada"
  ]
}

PLAY RECAP *****
cr-db-01 : ok=33  changed=5  unreachable=0  failed=0  s
kipped=3  rescued=0  ignored=1

creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$
```

Figura 7. CR-APPSRV-02 Hardening

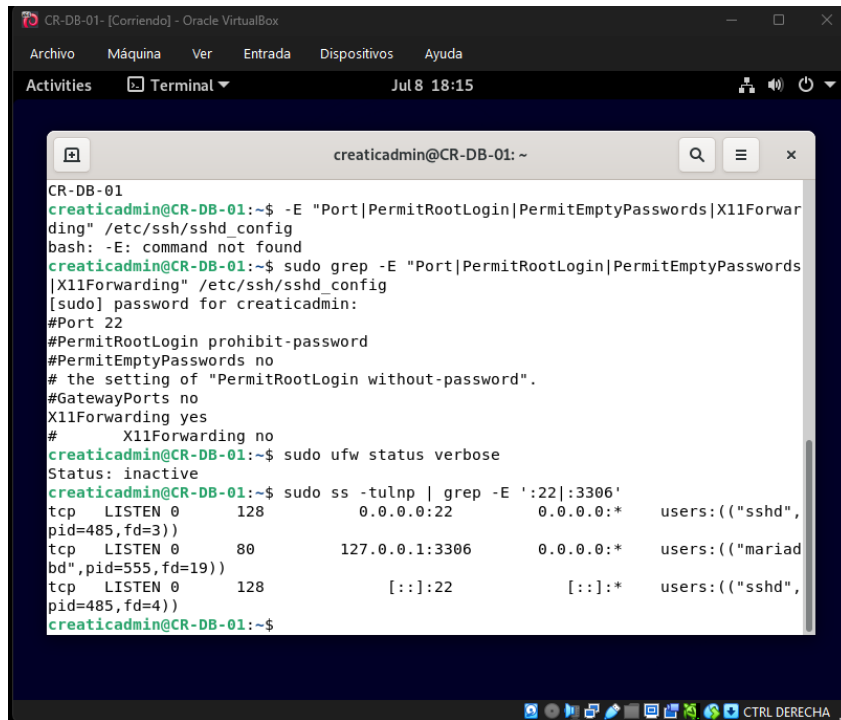


```
creaticadmin@CR-APPSRV-02: ~/creatic-hardening/linux

PLAY RECAP *****
cr-db-01 : ok=33  changed=5  unreachable=0  failed=0  s
kipped=3  rescued=0  ignored=1

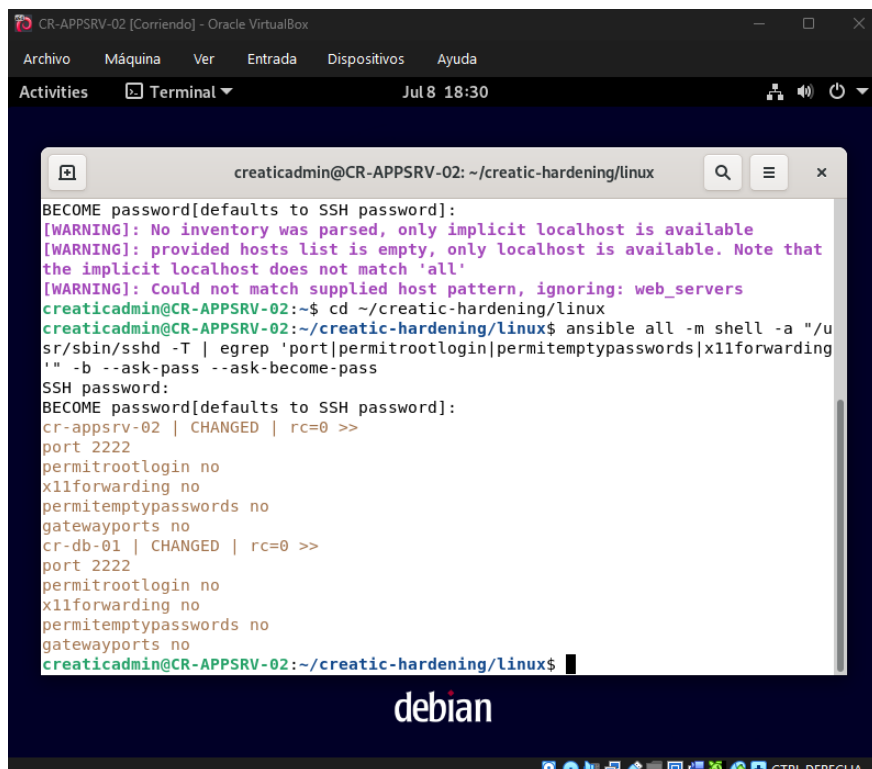
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ ansible all -m shell -a "su
do /usr/sbin/sshd -T | egrep 'port|permitrootlogin|permitemptypasswords|x11forwa
rding" --ask-pass --ask-become-pass
SSH password:
BECOME password[defaults to SSH password]:
[WARNING]: Consider using 'become', 'become_method', and 'become_user' rather
than running sudo
cr-appsrv-02 | CHANGED | rc=0 >>
port 2222
permitrootlogin no
x11forwarding no
permitemptypasswords no
gatewayports no
```

Figura 8. CR-APPSRV-02 Post-Hardening



```
CR-DB-01
creaticadmin@CR-DB-01:~$ -E "Port|PermitRootLogin|PermitEmptyPasswords|X11Forwarding" /etc/ssh/sshd_config
bash: -E: command not found
creaticadmin@CR-DB-01:~$ sudo grep -E "Port|PermitRootLogin|PermitEmptyPasswords|X11Forwarding" /etc/ssh/sshd_config
[sudo] password for creaticadmin:
#Port 22
#PermitRootLogin prohibit-password
#PermitEmptyPasswords no
# the setting of "PermitRootLogin without-password".
#GatewayPorts no
X11Forwarding yes
#
X11Forwarding no
creaticadmin@CR-DB-01:~$ sudo ufw status verbose
Status: inactive
creaticadmin@CR-DB-01:~$ sudo ss -tulnp | grep -E ':22|:3306'
tcp LISTEN 0      128          0.0.0.0:22          0.0.0.0:*        users:((("sshd",
pid=485,fd=3))
tcp LISTEN 0      80          127.0.0.1:3306      0.0.0.0:*        users:((("mariad
bd",pid=555,fd=19))
tcp LISTEN 0      128          [::]:22            [::]:*           users:((("sshd",
pid=485,fd=4))
creaticadmin@CR-DB-01:~$
```

Figura 9. CR-DB-01 Pre-Hardening



```
CR-APPSRV-02 [Corriendo] - Oracle VM VirtualBox
creaticadmin@CR-APPSRV-02: ~/creatic-hardening/linux
BECOME password[defaults to SSH password]:
[WARNING]: No inventory was parsed, only implicit localhost is available
[WARNING]: provided hosts list is empty, only localhost is available. Note that
the implicit localhost does not match 'all'
[WARNING]: Could not match supplied host pattern, ignoring: web_servers
creaticadmin@CR-APPSRV-02:~$ cd ~/creatic-hardening/linux
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$ ansible all -m shell -a "/u
sr/sbin/sshd -T | egrep 'port|permitrootlogin|permitemptypasswords|x11forwarding
'" -b --ask-pass --ask-become-pass
SSH password:
BECOME password[defaults to SSH password]:
cr-appsrv-02 | CHANGED | rc=0 >>
port 2222
permitrootlogin no
x11forwarding no
permitemptypasswords no
gatewayports no
cr-db-01 | CHANGED | rc=0 >>
port 2222
permitrootlogin no
x11forwarding no
permitemptypasswords no
gatewayports no
creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$
```

Figura 10. CR-APPSRV-02 SSH Post-Hardening

5.7 Hardening automatizado en Windows con PowerShell

Para los servidores Windows se desarrollaron scripts PowerShell ejecutables con privilegios administrativos. La automatización se separó por rol para mantener claridad operativa:

Script	Servidor	Rol
hardening_windows_dc.ps1	CR-DC-01	Servidor de identidad / controlador de dominio lógico
hardening_windows_file.ps1	CR-FILE-03	Servidor de archivos

Tabla 21. Scripts de hardening de Windows.

Ambos scripts aplican controles base comunes y controles específicos según la función del servidor. Esta separación permite mantener el principio de mínimo privilegio y evita aplicar configuraciones innecesarias en servidores que no lo requieren.

Controles aplicados en Windows

Control	Implementación técnica	Servidor impactado	Resultado esperado
Deshabilitar SMBv1	Set-SmbServerConfiguration - EnableSMB1Protocol \$false	CR-DC-01 / CR-FILE-03	Reducir riesgo de ransomware y explotación de SMB antiguo
Deshabilitar SMB1 como feature	Disable-WindowsOptionalFeature - FeatureName SMB1Protocol	CR-DC-01 / CR-FILE-03	Eliminar compatibilidad insegura
Política de contraseña	net accounts /MINPWLEN:12	CR-DC-01 / CR-FILE-03	Exigir contraseñas más robustas
Historial de contraseñas	net accounts /UNIQUEPW:5	CR-DC-01 / CR-FILE-03	Evitar reutilización inmediata
Bloqueo de cuenta	LOCKOUTTHRESHOLD:5	CR-DC-01 / CR-FILE-03	Reducir ataques de fuerza bruta

Deshabilitar Guest	Disable-LocalUser -Name Guest	CR-DC-01 / CR-FILE-03	Evitar acceso no autorizado
Activar firewall	Set-NetFirewallProfile -Enabled True	CR-DC-01 / CR-FILE-03	Asegurar protección local
Bloquear entrada por defecto	DefaultInboundAction Block	CR-DC-01 / CR-FILE-03	Aplicar política restrictiva
SMB Signing	RequireSecuritySignature \$true	CR-DC-01	Proteger autenticación SMB
Auditoría de identidad	auditpol	CR-DC-01	Registrar eventos de logon y cambios de cuentas
Permisos del recurso compartido	Remoción de Everyone y uso de grupo autorizado	CR-FILE-03	Reducir acceso excesivo a archivos

Tabla 22. Controles aplicados en Windows.

5.8 Verificación post-hardening en Windows

Después de ejecutar los scripts, se realizaron verificaciones para confirmar el estado seguro de cada servidor.

Verificaciones realizadas en CR-DC-01

Verificación	Comando	Resultado esperado
Hostname	hostname	CR-DC-01
SMBv1	Get-SmbServerConfiguration	EnableSMB1Protocol: False
SMB Signing	RequireSecuritySignature	True
Política de contraseñas	net accounts	Longitud mínima 12, bloqueo por 5 intentos
Cuenta Guest	Get-LocalUser Guest	Enabled: False
Firewall	Get-NetFirewallProfile	Perfiles habilitados

Auditoría	auditpol /get	Logon, Account Lockout y User Account Management habilitados
------------------	---------------	--

Tabla 23. Tareas de verificación de controles en activo CR-DC-01.

Verificaciones realizadas en CR-FILE-03

Verificación	Comando	Resultado esperado
Hostname	hostname	CR-FILE-03
SMBv1	Get-SmbServerConfiguration	EnableSMB1Protocol: False
Política de contraseñas	net accounts	Longitud mínima 12, bloqueo por 5 intentos
Cuenta Guest	Get-LocalUser Guest	Enabled: False
Firewall	Get-NetFirewallProfile	Perfiles habilitados
Recursos compartidos	Get-SmbShare	Recurso CREATIC-Files creado o validado
Permisos del share	Get-SmbShareAccess	Sin permisos amplios de Everyone

Tabla 24. Tareas de verificación de controles en activo CR-FILE-03.

```

CR-DC-01 [Comando] - Oracle VirtualBox
Administrador: Windows PowerShell
>> Get-NetFirewallProfile | Format-Table Name Enabled DefaultInboundAction DefaultOutboundAction -AutoSize
===== CR-DC-01 - EXISTENCIA PRE-HARDENING =====
===== IDENTIFICACION DEL SERVIDOR =====
CR-DC-01
===== SMBv1 =====
EnableSMB1Protocol : True

===== POLITICA DE CONTRASENAS =====
Force user logoff how long after time expires?: Never
Minimum password age (days): 0
Maximum password age (days): 42
Minimum password length: 0
Length of password history maintained: None
Lockout threshold: Never
Lockout duration (minutes): 30
Lockout observation window (minutes): 30
Computer role: SERVER
The command completed successfully.

===== CUENTA GUEST =====
Name : Guest
Enabled : False
Description : Built-in account for guest access to the computer/domain

===== FIREWALL =====
Name Enabled DefaultInboundAction DefaultOutboundAction
-----
Domain True NotConfigured NotConfigured
Private True NotConfigured NotConfigured
Public True NotConfigured NotConfigured

PS C:\CREATIC-Hardening>

```

Figura 11. CR-DC-01 Pre-Hardening

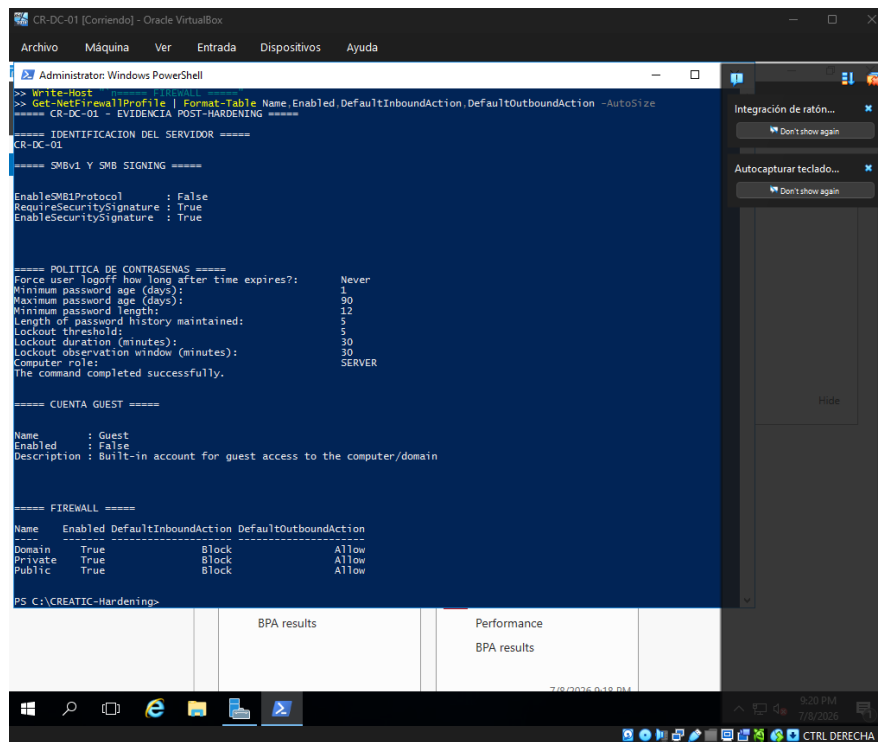


Figura 12. CR-DC-01 Post-Hardening

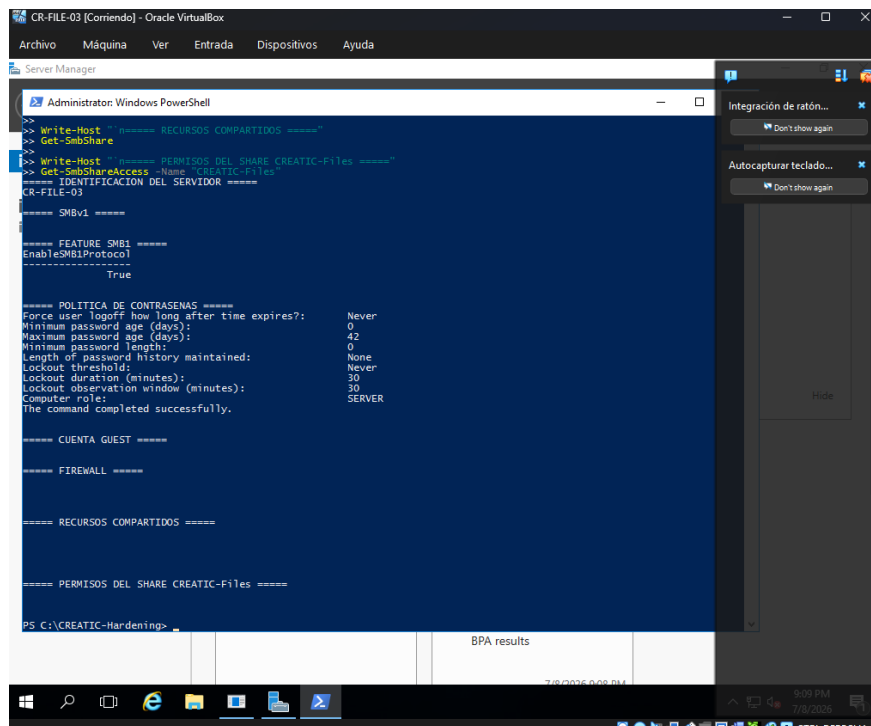


Figura 13. CR-FILE-03 Pre-Hardening

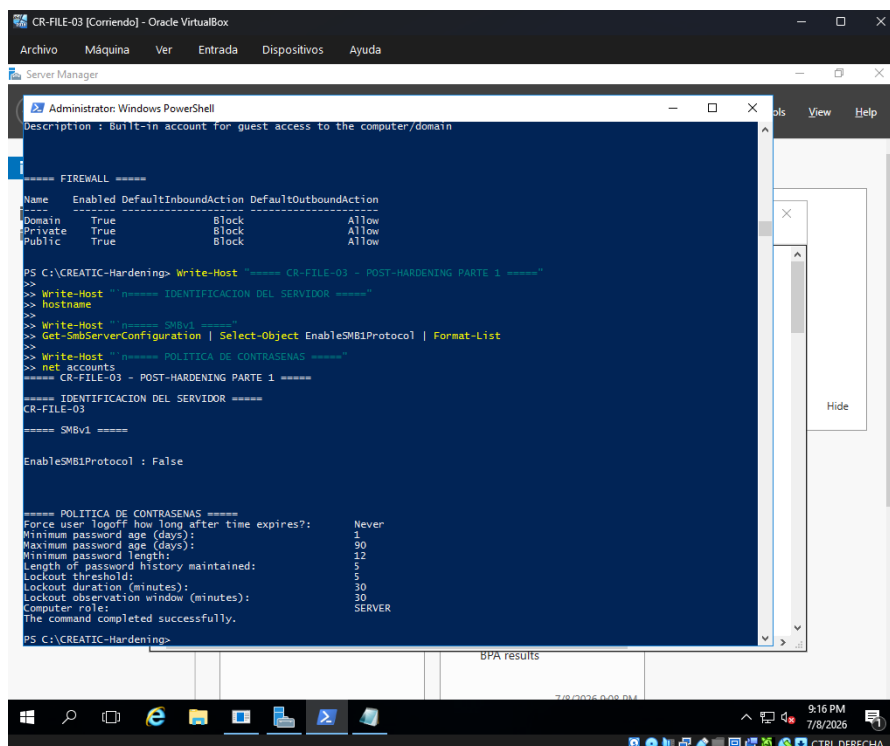


Figura 14. CR-FILE-03 Post-Hardening Pt.1

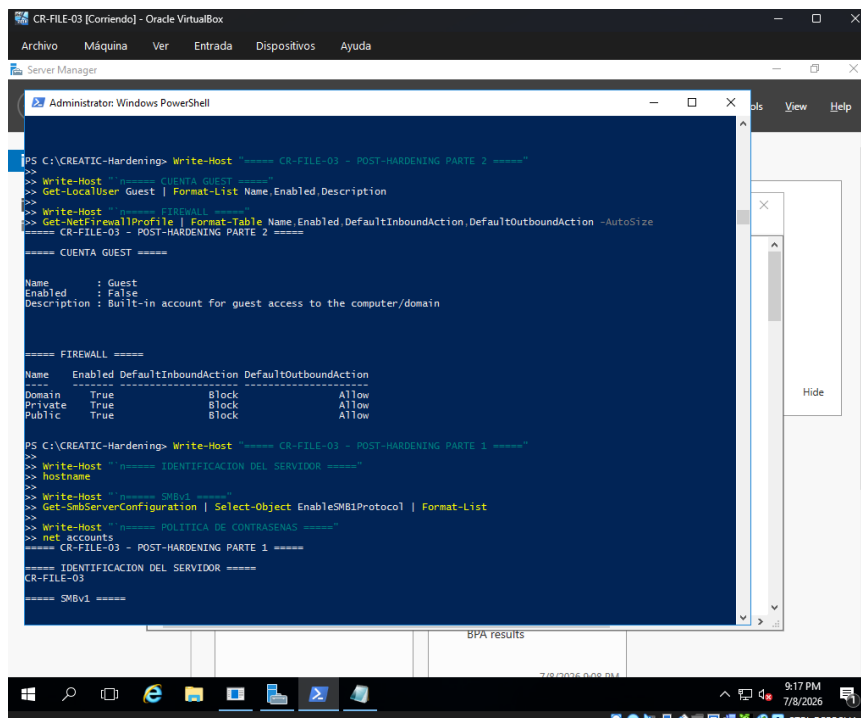


Figura 15. CR-FILE-03 Post-Hardening Pt.2

5.9 Relación del hardening con Zero Trust y Defensa en Profundidad

El hardening automatizado fortalece directamente la arquitectura Zero Trust planteada en el Módulo 2. Aunque la microsegmentación, el ZTNA y el MFA reducen el acceso no autorizado, los servidores también deben estar configurados para resistir intentos de explotación directa, abuso de credenciales y movimiento lateral.

La automatización implementada contribuye a los tres principios principales de Zero Trust:

Principio Zero Trust	Aplicación en el Módulo 5
Verificar continuamente	Se validan configuraciones post-hardening mediante comandos y salidas verificables.
Otorgar mínimo privilegio	Se restringen puertos, servicios, cuentas y permisos de recursos compartidos.
Asumir la brecha	Se reducen caminos de movimiento lateral mediante firewall local, bloqueo de SMBv1 y endurecimiento de SSH.

Tabla 25. Principios Zero Trust.

Además, el hardening complementa la defensa en profundidad porque agrega una capa de protección directamente sobre los servidores. De esta forma, aunque un atacante logre superar un control perimetral, encontrará restricciones adicionales en el sistema operativo, los servicios, el firewall local y las políticas de autenticación.

5.10 Tabla de resumen de controles implementados

Activo	Debilidad inicial	Control automatizado	Herramienta	Evidencia esperada
CR-APPSR V-02	SSH en puerto 22, root habilitado, servicios sin hardening	SSH 2222, root deshabilitado, UFW, Fail2ban, paquetes inseguros removidos	Ansible	Captura SSH/UFW/Apache
CR-DB-01	Base de datos	UFW restringe	Ansible	Captura MariaDB/UFW/SSH

	expuesta en mismo entorno, controles locales débiles	MariaDB solo desde CR-APPSRV-02, SSH endurecido, Fail2ban		
CR-DC-01	SMBv1 activo, políticas por defecto, Guest disponible	SMBv1 deshabilitado, SMB Signing, firewall, política de contraseñas, auditoría	PowerShell	Captura SMB/Firewall/Guest/Auditoría
CR-FILE-03	Permisos laxos y exposición a ransomware	SMBv1 deshabilitado, Guest deshabilitado, firewall, permisos del share ajustados	PowerShell	Captura permisos/SMB/Firewall

Tabla 26. Controles Implementados

5.11 Evidencias generadas

Como parte del laboratorio se generaron evidencias pre-hardening y post-hardening para cada servidor. Estas capturas permiten demostrar la condición inicial del sistema, la ejecución de los scripts y el estado final después de aplicar los controles.

Las evidencias se agrupan de la siguiente manera:

Grupo de evidencia	Descripción
Evidencias Linux pre-hardening	Estado inicial de SSH, UFW, Apache y MariaDB
Evidencias Linux post-hardening	Validación de puerto SSH 2222, UFW activo, Fail2ban y servicios críticos
Evidencias Windows pre-hardening	Estado inicial de SMBv1, Guest, firewall, políticas de contraseña y recursos compartidos

Evidencias Windows post-hardening	Validación de SMBv1 deshabilitado, firewall activo, Guest deshabilitado y políticas restrictivas
--	--

Tabla 27. Evidencias generadas.

Estas evidencias deben anexarse en el documento final o mantenerse dentro de la carpeta evidencias/ del repositorio.

5.12 Limitaciones del laboratorio

El laboratorio fue desarrollado en un entorno virtualizado local utilizando máquinas virtuales. Por esta razón, algunas configuraciones fueron implementadas con fines demostrativos y pueden requerir ajustes adicionales antes de su aplicación en un entorno productivo.

Entre las principales limitaciones se identifican:

- El entorno no representa toda la complejidad de una red institucional real.
- Las reglas de firewall fueron definidas para el laboratorio y deben ajustarse a los rangos reales de producción.
- La validación de parches y vulnerabilidades fue abordada a nivel de configuración base, no como un ciclo completo de gestión de vulnerabilidades.
- La integración con Wazuh se considera parte de la arquitectura del Módulo 3, por lo que en este módulo se prioriza la automatización de hardening local.

Si por limitaciones de rendimiento se utilizó una versión equivalente de Windows Server en el laboratorio, se mantiene el rol lógico de cada activo y los controles aplicados siguen siendo válidos para demostrar la automatización requerida.

5.13 Resultado del módulo

El resultado del Módulo 5 es la implementación de una estrategia de hardening automatizado sobre los cuatro activos críticos de CREATIC. La solución permite pasar de configuraciones inseguras y manuales a un modelo controlado, repetible y verificable mediante código.

Los principales resultados obtenidos fueron:

- Automatización del hardening Linux mediante Ansible.
- Automatización del hardening Windows mediante PowerShell.
- Reducción de exposición por SSH inseguro.
- Deshabilitación de SMBv1 en servidores Windows.
- Fortalecimiento de políticas de autenticación.

- Deshabilitación de cuentas invitadas.
- Activación de firewall local.
- Restricción de permisos en recursos compartidos.
- Validación post-hardening mediante comandos verificables.
- Organización de scripts y evidencias en repositorio.

Estos resultados cumplen con el requisito técnico del proyecto, el cual exige entregar código de infraestructura para Linux y Windows, con parametrización, comentarios explicativos y verificación post-hardening.

5.14 Conclusión del módulo

La automatización de hardening implementada en este módulo fortalece la postura de seguridad de CREATIC al reducir configuraciones inseguras en servidores críticos y establecer una base técnica repetible para futuras remediaciones.

En los servidores Linux, Ansible permitió endurecer el acceso SSH, aplicar reglas de firewall local, eliminar servicios innecesarios y validar el funcionamiento de Apache y MariaDB. En los servidores Windows, PowerShell permitió deshabilitar SMBv1, fortalecer políticas de contraseñas, inhabilitar la cuenta Guest, activar el firewall y ajustar controles específicos según el rol del servidor.

Este módulo convierte las recomendaciones de seguridad en controles técnicos ejecutables, alineados con Zero Trust, defensa en profundidad y monitoreo continuo. Además, proporciona evidencia verificable del antes y después, facilitando auditorías, sustentación académica y mantenimiento futuro de la infraestructura.

Con esta implementación, CREATIC reduce su exposición frente a ataques de fuerza bruta, movimiento lateral, abuso de SMB, ransomware y uso indebido de cuentas privilegiadas, fortaleciendo la protección de activos críticos como CR-DC-01, CR-APPSRV-02, CR-DB-01 y CR-FILE-03.

MÓDULO 6: Cumplimiento Regulatorio

6.1 Introducción

El Instituto Tecnológico CREATIC procesa datos personales, académicos y financieros de estudiantes, docentes y personal administrativo, por lo que la arquitectura de ciberseguridad propuesta debe alinearse con la **Ley 81 de Protección de Datos Personales de Panamá**. Esta ley exige que el tratamiento de datos personales respete principios como finalidad, proporcionalidad, seguridad, confidencialidad y licitud. En particular, establece que los responsables del tratamiento deben adoptar medidas técnicas y organizativas

necesarias para garantizar la seguridad de los datos bajo su custodia, especialmente cuando se trate de datos sensibles o confidenciales.

Para cumplir con este marco legal, la propuesta incorpora controles técnicos como cifrado de datos, autenticación multifactor, segmentación de red, monitoreo centralizado con Wazuh, políticas de retención de logs y trazabilidad de accesos. Estos controles permiten reducir el riesgo de acceso no autorizado, pérdida de información, alteración de registros académicos o exposición de datos personales.

6.2 Tabla de mapeo normativo Ley 81 y controles técnicos

Artículo / Principio Ley 81	Exigencia normativa aplicable	Control técnico propuesto	Entregable del proyecto que lo implementa
Art. 2 — Principio de finalidad	Los datos deben usarse únicamente para fines determinados y no conservarse más tiempo del necesario.	Política de retención de logs, eliminación segura y uso limitado de registros de seguridad.	Módulo 3: SOC/Wazuh. Módulo 6: Política de retención de logs.
Art. 2 — Principio de proporcionalidad	Solo deben tratarse los datos adecuados, pertinentes y mínimos necesarios.	Recolección mínima de logs: usuario, IP origen, evento, recurso accedido, resultado MFA y alerta asociada.	Módulo 3: Fuentes de ingesta SIEM. Módulo 6: Retención y minimización.
Art. 2 — Principio de seguridad de los datos	Se deben adoptar medidas técnicas y organizativas para proteger los datos bajo custodia.	Cifrado en reposo, cifrado en tránsito, MFA, hardening, segmentación, Wazuh SIEM/EDR y control de acceso.	Módulo 2: Zero Trust. Módulo 3: SOC. Módulo 5: Hardening.
Art. 2 — Principio de confidencialidad	Quienes intervienen en el tratamiento deben impedir acceso o uso no autorizado.	RBAC, mínimo privilegio, MFA, cuentas administrativas separadas y registros de acceso.	Módulo 2: ZTNA/MFA. Módulo 3: Monitoreo.

Art. 5 y Art. 7	El responsable o custodio debe cumplir estándares, protocolos y procedimientos de gestión y transferencia segura.	Documentación de arquitectura, procedimientos de acceso seguro, monitoreo, respuesta a incidentes y transferencia cifrada.	Documento técnico principal. Módulo 2, 3, 5 y 7.
Art. 13 — Datos sensibles	Los datos sensibles no deben transferirse salvo autorización o causa legal válida.	MFA, cifrado TLS, segmentación, restricción de transferencia y registro de accesos a datos sensibles.	Módulo 2: ZTNA/MFA. Módulo 3: Wazuh. Módulo 6: Justificación MFA.
Art. 28	No deben comunicarse datos personales después de vencido el plazo legal de conservación aplicable.	Política de retención: conservación limitada, archivo cifrado y eliminación segura al vencer el plazo.	Módulo 6: Política de retención de logs.
Art. 31	Debe mantenerse registro de bases de datos, medidas de seguridad, protocolos, tiempo de conservación e identificación de accesos.	Inventario de activos, registro de accesos, logs centralizados, documentación de medidas técnicas y trazabilidad en Wazuh.	Módulo 1: Activos. Módulo 3: SIEM. Módulo 6: Anexo normativo.
Art. 40, 41, 42 y 43	El incumplimiento puede derivar en faltas graves o muy graves, incluyendo sanciones y suspensión o clausura de registros.	Evidencia de cumplimiento mediante SIEM, controles de acceso, hardening, respuesta a incidentes y auditoría.	Módulo 3: SOC. Módulo 5: Hardening. Módulo 7: IRP.

Tabla 28. Aplicación de la Ley 81.

6.3 Política de retención de logs

La Ley 81 no establece un único plazo técnico específico para la conservación de logs de seguridad; sin embargo, exige que los datos personales no se conserven por más tiempo del necesario para la finalidad del tratamiento y que el responsable documente el tiempo de conservación, medidas de seguridad y accesos a las bases de datos.

Por tanto, CREATIC adoptará la siguiente política de retención de logs:

Tipo de log	Ejemplos	Retención propuesta	Implementación técnica
Logs críticos de seguridad	Alertas Wazuh, Suricata, pfSense, intentos de acceso fallidos, MFA fallido	12 meses en Wazuh Indexer	Índices activos con búsqueda rápida para investigación y respuesta.
Logs de autenticación e identidad	Keycloak, Headscale, Tailscale, accesos ZTNA, eventos MFA	12 meses en Wazuh Indexer	Control de acceso RBAC, MFA para analistas y trazabilidad de consultas.
Logs administrativos	Cambios en grupos privilegiados, creación de usuarios, acceso a CR-DC-01 y CR-FILE-03	24 meses archivados	Archivo cifrado, acceso restringido al SOC/CSIRT y hash de integridad.
Logs de base de datos	Accesos administrativos, errores MySQL, consultas privilegiadas	24 meses archivados	Cifrado, segmentación y revisión por incidentes relacionados con CR-DB-01.
Logs asociados a incidentes confirmados	Evidencia de ransomware, exfiltración, abuso de credenciales o brecha	Hasta cierre del caso y plazo legal aplicable	Conservación bajo “legal hold”, solo accesible al CSIRT y responsables autorizados.
Logs vencidos sin valor legal u operativo	Registros antiguos sin incidente asociado	Eliminación segura	Borrado programado mediante política de ciclo de vida del SIEM.

Tabla 29. Políticas de retención de Logs.

La política general será conservar los logs operativos durante el tiempo estrictamente necesario para monitoreo, investigación y respuesta a incidentes. Los registros que contengan datos personales serán protegidos mediante cifrado, control de acceso, segregación de funciones y eliminación segura al finalizar su periodo de retención. En caso de investigación, incidente confirmado o requerimiento legal, los logs podrán conservarse por el plazo necesario, sin exceder los límites legales aplicables. La Ley 81 establece que no deben comunicarse datos personales después de transcurridos siete años desde que se extinguió la obligación legal de conservarlos, salvo solicitud expresa del titular.

En Wazuh, esta política se implementará mediante ciclos de vida de índices, archivo cifrado, restricción de acceso por roles, monitoreo de consultas administrativas y generación de evidencia para auditoría. Los logs no deberán utilizarse para fines distintos a seguridad, auditoría, cumplimiento regulatorio o investigación de incidentes.

6.4 Justificación del MFA frente al Artículo 13 y el principio de seguridad

El Artículo 13 de la Ley 81 establece restricciones para la transferencia de datos sensibles, permitiendo su tratamiento o transferencia únicamente bajo supuestos autorizados, como autorización explícita del titular, obligación legal o finalidades justificadas. En el contexto de CREATIC, esto implica que el acceso a datos académicos, financieros y personales debe estar limitado a usuarios autorizados y bajo controles técnicos que reduzcan el riesgo de divulgación o transferencia no autorizada.

La autenticación multifactor cumple una función clave dentro de este control porque evita que una contraseña comprometida sea suficiente para acceder a sistemas que contienen datos sensibles. Bajo la arquitectura propuesta, todo acceso remoto o administrativo hacia recursos críticos deberá pasar por Keycloak con MFA, validación del dispositivo y autorización por rol. Esto fortalece el principio de seguridad de los datos establecido en la Ley 81, el cual exige medidas técnicas y organizativas para proteger los datos personales bajo custodia.

En términos técnicos, el MFA propuesto contribuye al cumplimiento de la Ley 81 de la siguiente forma:

Riesgo legal/técnico	Control MFA aplicado	Resultado esperado
Uso de credenciales robadas	Segundo factor obligatorio TOTP/FIDO2	Reduce el riesgo de acceso no autorizado.
Acceso indebido a CR-DB-01	MFA + RBAC + segmentación	Solo usuarios autorizados pueden acceder a datos sensibles.

Transferencia no autorizada de datos	MFA + registro de sesión + Wazuh	Toda acción queda trazable para auditoría.
Abuso de cuentas administrativas	MFA obligatorio para TI y cuentas privilegiadas	Disminuye riesgo de escalada de privilegios.
Falta de evidencia ante auditoría	Registro de autenticación, IP origen, dispositivo y recurso accedido	Permite demostrar controles de seguridad y trazabilidad.

Tabla 30. Cumplimiento de Ley 81.

Por tanto, el MFA no se implementa únicamente como una medida de autenticación, sino como un control legal y técnico que protege la confidencialidad, integridad y trazabilidad del tratamiento de datos personales.

6.5 Conclusión del módulo

El cumplimiento regulatorio de CREATIC se fortalece mediante la integración de controles técnicos directamente alineados con la Ley 81 de Protección de Datos Personales. La combinación de cifrado, MFA, Zero Trust, segmentación, hardening, SIEM, retención controlada de logs y respuesta a incidentes permite proteger los datos académicos, financieros y personales bajo custodia institucional.

Además, estos controles reducen la exposición legal de la institución frente a infracciones graves, como almacenar datos personales sin condiciones adecuadas de seguridad o no aplicar medidas apropiadas para proteger datos sensibles. La Ley 81 contempla sanciones para incumplimientos, y ANTAI señala que pueden existir multas y, en faltas muy graves, clausura de registros de bases de datos.

MÓDULO 7: Gestión de Riesgos y Respuesta a Incidentes

7.1 Metodología de gestión de riesgos

Para la gestión de riesgos de CREATIC se utiliza un enfoque basado en **NIST SP 800-30**, el cual permite identificar amenazas, vulnerabilidades, probabilidad de ocurrencia, impacto sobre la triada CIA y controles de mitigación. El riesgo inherente se calcula antes de aplicar controles, mientras que el riesgo residual representa el nivel de riesgo restante después de implementar las medidas propuestas en la arquitectura Zero Trust, el SOC con Wazuh, el hardening automatizado y el ciclo DevSecOps.

La valoración utilizada es la siguiente:

Valor	Probabilidad	Impacto CIA
1	Muy baja	Impacto mínimo
2	Baja	Impacto menor
3	Media	Impacto moderado
4	Alta	Impacto alto
5	Muy alta	Impacto crítico

Tabla 31 - Valoración de impacto

El cálculo del riesgo inherente se define como:

Riesgo Inherente = Probabilidad × Impacto CIA

Rango	Nivel de riesgo
1 – 5	Bajo
6 – 10	Medio
11 – 15	Alto
16 – 25	Crítico

Tabla 32 - Rango de Riesgo Inherente

7.2 Matriz de riesgos

Activo	Amenaza	Vulnerabilidad	Probabilidad (1-5)	Impacto CIA (1-5)	Riesgo Inherente	Control Propuesto	Riesgo Residual
CR-DC-01	Compromiso de cuentas administrativas	Credenciales expuestas, ausencia de MFA y controles de acceso débiles	4	5	20 - Crítico	MFA, ZTNA, mínimo privilegio, monitoreo de eventos de AD en Wazuh y alertas por cambios en grupos privilegiados	8 - Medio
CR-DC-01	Movimiento lateral y escalada de privilegios	SMBv1 activo, sistema sin parches y falta de monitoreo centralizado	3	5	15 - Alto	Deshabilitar SMBv1, aplicar hardening PowerShell, gestión de parches	6 - Medio

						y reglas de correlación en Wazuh	
CR-APPS RV-02	Explotación de aplicación vulnerable	Apache desactualizado, despliegues manuales y ausencia de SAST/DAST/SCA	4	4	16 - Crítico	Pipeline DevSecOps con Semgrep, OWASP Dependency-Check, OWASP ZAP, Trivy y ModSecurity WAF	8 - Medio
CR-APPS RV-02	Acceso SSH no autorizado	SSH expuesto en puerto 22, login root permitido y autenticación por contraseña	4	4	16 - Crítico	Playbook Ansible para deshabilitar root login, cambiar puerto SSH, usar autenticación segura y configurar UFW	6 - Medio
CR-DB-01	Exfiltración de datos académicos y financieros	Base de datos en el mismo segmento que el servidor web y sin cifrado en reposo	3	5	15 - Alto	VLAN dedicada para DB, cifrado en reposo, control de acceso por cuenta de servicio, logs MySQL y monitoreo en Wazuh	6 - Medio
CR-DB-01	Alteración de calificaciones o registros financieros	Falta de segregación, privilegios excesivos y ausencia de auditoría detallada	3	5	15 - Alto	RBAC, mínimo privilegio, auditoría de consultas administrativas,	6 - Medio

						backups y revisión de integridad	
CR- FILE- 03	Acceso no autorizado a document os administra tivos	Permisos laxos y carpetas críticas legibles por “Everyone”	4	4	16 - Crítico	Revisión de permisos NTFS, eliminación de “Everyone” , grupos por rol y auditoría de acceso a carpetas	8 - Medio
CR- FILE- 03	Ransomw are sobre archivos compartid os	SMBv1, permisos excesivos y falta de respuesta automática	4	5	20 - Crítico	Deshabilita r SMBv1, FIM con Wazuh, backups aislados, Active Response y bloqueo SMB desde host compromet ido	8 - Medio

Tabla 33 - Matriz de Riesgo

7.3 Plan de Respuesta a Incidentes Simplificado

El Plan de Respuesta a Incidentes de CREATIC tiene como objetivo establecer una guía operativa para detectar, contener, erradicar y recuperar incidentes de ciberseguridad que afecten los activos críticos de la institución. El plan se basa en un ciclo simplificado de respuesta: **preparación, detección y análisis, contención, erradicación, recuperación y lecciones aprendidas.**

7.3.1 Fases del IRP

Fase	Objetivo	Actividades principales
Preparación	Asegurar que CREATIC cuente con roles, herramientas y procedimientos definidos.	Configurar Wazuh, definir alertas, documentar contactos CSIRT, mantener respaldos y capacitar usuarios.
Detección y análisis	Identificar eventos sospechosos y	Analizar alertas Wazuh, Suricata, pfSense, Keycloak y logs de servidores.

	clasificarlos según criticidad.	
Contención	Limitar el impacto del incidente y evitar propagación.	Bloquear IPs, aislar endpoints, cerrar sesiones, deshabilitar cuentas comprometidas y aplicar reglas temporales en pfSense.
Erradicación	Eliminar la causa raíz del incidente.	Remover malware, corregir vulnerabilidades, aplicar parches, rotar credenciales y validar hardening.
Recuperación	Restaurar servicios de forma segura.	Recuperar desde backups, validar integridad, monitorear actividad posterior y habilitar servicios gradualmente.
Lecciones aprendidas	Mejorar controles y reducir recurrencia.	Documentar causa raíz, tiempos de respuesta, impacto, controles fallidos y acciones de mejora.

Tabla 34 - Fases de IRP

7.4 Roles esenciales del CSIRT interno

Rol	Responsabilidad
Coordinador CSIRT	Dirige la respuesta, prioriza acciones, comunica decisiones y coordina con la alta gerencia.
Analista SOC	Monitorea alertas en Wazuh, valida eventos, clasifica incidentes y escala casos críticos.
Administrador de Sistemas	Aplica acciones sobre servidores Windows/Linux, cuentas, servicios, parches y restauración.
Ingeniero de Red y Seguridad	Gestiona reglas en pfSense, Suricata, segmentación, bloqueo de IPs y contención de tráfico.
Responsable DevSecOps	Atiende incidentes relacionados con el Portal Académico, dependencias vulnerables, código y pipeline CI/CD.
Responsable Legal/Cumplimiento	Evalúa implicaciones regulatorias, Ley 81, custodia de evidencia y notificación según corresponda.
Comunicación Institucional	Prepara mensajes internos o externos autorizados, evitando divulgación no validada del incidente.

Tabla 35 – Roles esenciales del CSIRT interno

7.5 Clasificación de severidad de incidentes

Severidad	Criterio	Ejemplo
Crítica	Afecta datos sensibles, dominio, base de datos, ransomware activo o interrupción institucional.	Compromiso de CR-DC-01, cifrado de CR-FILE-03 o exfiltración de CR-DB-01.
Alta	Compromete un servidor importante o evidencia movimiento lateral.	Explotación de CR-APPSRV-02 o tráfico no autorizado entre VLANs.
Media	Evento sospechoso contenido sin impacto confirmado.	Intentos SSH fallidos, MFA fallido repetido o escaneo interno.
Baja	Evento aislado sin evidencia de compromiso.	Alerta informativa o intento bloqueado automáticamente.

Tabla 36 - Clasificación de severidad

7.6 Acciones inmediatas ante incidente crítico

Ante una inyección de incidente durante la sustentación o ante un evento crítico real, el equipo CSIRT deberá ejecutar tres acciones iniciales:

Acción	Descripción
1. Contener la amenaza	Aislar el host afectado, bloquear IPs maliciosas en pfSense, deshabilitar cuentas comprometidas y detener comunicación no autorizada entre VLANs.
2. Preservar evidencia	Exportar logs de Wazuh, pfSense, Suricata, Keycloak y servidores afectados, manteniendo trazabilidad para análisis forense y cumplimiento.
3. Recuperar y erradicar	Aplicar parches, rotar credenciales, restaurar desde backups verificados y validar que el activo vuelva a operación segura.

Tabla 37 - Acciones inmediatas

7.7 KPIs y KRIs de gestión

Indicador	Tipo	Descripción	Meta propuesta
MTTD	KPI	Tiempo medio desde que ocurre un evento hasta que es detectado por el SOC.	≤ 30 minutos para incidentes críticos
MTTR	KPI	Tiempo medio desde la detección hasta la contención inicial del incidente.	≤ 4 horas para incidentes críticos

Porcentaje de alertas críticas atendidas	KPI	Mide la capacidad del SOC para responder alertas prioritarias.	≥ 95%
Porcentaje de servidores reportando a Wazuh	KPI	Verifica cobertura de monitoreo sobre activos críticos.	100% de servidores del inventario
Intentos fallidos de MFA	KRI	Incremento anormal puede indicar credential stuffing o abuso de credenciales.	Alerta ante aumento significativo
Cambios en grupos privilegiados	KRI	Creación o modificación de cuentas administrativas.	Alerta crítica inmediata
Modificaciones masivas de archivos	KRI	Indicador temprano de ransomware en CR-FILE-03.	Alerta ante más de 100 cambios/minuto
Vulnerabilidades críticas sin remediar	KRI	Riesgo asociado a falta de parches o dependencias vulnerables.	0 vulnerabilidades críticas activas

Tabla 38 - Indicadores de Rendimiento

7.8 Conclusión del módulo

La gestión de riesgos permite priorizar los activos más críticos de CREATIC y establecer controles técnicos alineados con la arquitectura propuesta. La matriz evidencia que los mayores riesgos se concentran en el compromiso del Controlador de Dominio, la explotación del Portal Académico, la exposición de la base de datos y el ransomware sobre el servidor de archivos.

El Plan de Respuesta a Incidentes proporciona una guía operativa para actuar de forma ordenada ante eventos críticos, definiendo roles, fases, acciones inmediatas y métricas de gestión. La integración de Wazuh, pfSense, Suricata, Keycloak, controles Zero Trust, hardening y DevSecOps permite reducir el riesgo residual y mejorar la capacidad de detección, contención y recuperación de CREATIC.

Enlace del Repositorio

El siguiente repositorio contiene la documentación técnica completa del proyecto de ciberseguridad para CREATIC. Incluye el documento principal, evidencias de laboratorio, scripts de automatización, playbooks de Ansible, scripts de PowerShell, configuraciones utilizadas, capturas de validación y demás archivos de soporte desarrollados durante los módulos del proyecto. Su propósito es centralizar los entregables técnicos y demostrar la trazabilidad entre la arquitectura propuesta, la automatización del hardening y las evidencias generadas.

Repositorio: <https://github.com/idcasis/creatic-zero-trust-security>

Referencias Bibliográficas

National Institute of Standards and Technology. (2020). *Zero Trust Architecture (NIST Special Publication 800-207)*. U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/207/final>

Cybersecurity and Infrastructure Security Agency, National Security Agency, & Federal Bureau of Investigation. (2022). *Cybersecurity advisories: Weak security controls and practices routinely exploited for initial access*. National Security Agency. https://media.defense.gov/2022/May/17/2002998718/-1/-1/0/CSA_WEAK_SECURITY_CONTROLS_PRACTICES_EXPLOITED_FOR_INITIAL_ACCESS.PDF

Mandiant. (2024). *M-Trends 2024: Insights into today's cyber threat landscape*. Google Cloud. <https://cloud.google.com/security/resources/m-trends>

Center for Internet Security. (s. f.). *CIS Benchmarks*. <https://learn.cisecurity.org/benchmarks>

The MITRE Corporation. (s. f.). *MITRE ATT&CK® Enterprise Matrix*. MITRE. Recuperado el 9 de julio de 2026, de <https://attack.mitre.org/matrices/enterprise/>

National Institute of Standards and Technology. (2009). *Guide to General Server Security (NIST Special Publication 800-123)*. U.S. Department of Commerce. <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-123.pdf>

International Organization for Standardization. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. International Organization for Standardization. <https://www.iso.org/standard/27001.html>

National Institute of Standards and Technology. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management (NIST Special Publication 800-61 Revision 3)*. U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

Cybersecurity and Infrastructure Security Agency, & National Institute of Standards and Technology. (2021). *Defending against software supply chain attacks*. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/resources-tools/resources/defending-against-software-supply-chain-attacks>

OWASP Foundation. (s. f.). *OWASP Top Ten: Web application security risks*. Open Worldwide Application Security Project. Recuperado el 9 de julio de 2026, de <https://owasp.org/www-project-top-ten/>

Asamblea Nacional de Panamá. (2019). *Ley 81 de 2019 sobre protección de datos personales*. República de Panamá. https://s3-legispan.asamblea.gob.pa/legispan/NORMAS/2010/2019/LEY/Administrador%20Legispan_28743-A_2019_3_29_ASAMBLEA%20NACIONAL_81.pdf

Autoridad Nacional de Transparencia y Acceso a la Información. (s. f.). *Preguntas frecuentes: Protección de datos personales*. <https://antai.gob.pa/preguntas-frecuentes-proteccion-de-datos-personales/>

Verizon Business. (2025). *2025 Data Breach Investigations Report (DBIR)*. Verizon. <https://www.verizon.com/business/resources/reports/2025-dbir-data-breach-investigations-report.pdf>

StrangeBee. (s. f.). *TheHive: Security incident response platform*. StrangeBee. Recuperado el 9 de julio de 2026, de <https://strangebee.com/thehive/>

Shuffle. (s. f.). *Shuffle: Open source security orchestration, automation and response (SOAR) platform*. Recuperado el 9 de julio de 2026, de <https://shuffler.io>

Wazuh, Inc. (s. f.). *Wazuh: The open source security platform*. Recuperado el 9 de julio de 2026, de <https://wazuh.com>

Keycloak Authors. (s. f.). *Keycloak: Open source identity and access management*. Keycloak. Recuperado el 9 de julio de 2026, de <https://www.keycloak.org>

Netgate. (s. f.). *pfSense®: Open source firewall and router platform*. pfSense. Recuperado el 9 de julio de 2026, de <https://www.pfsense.org>

OWASP Foundation. (s. f.). *ModSecurity: Open source web application firewall (WAF) engine*. OWASP. Recuperado el 9 de julio de 2026, de <https://modsecurity.org>